🌐 Module 05: Web Application Penetration Testing

```
# Exercise 6: Performing Dictionary Attack on a WordPress Web Application using Burp Suite
```

Scenario

Using weak username/password combinations to log in to web applications might allow attackers to brute-force them and gain access to them. This leads to unrestricted access to user accounts and manipulation of data in those accounts.

As a penetration tester, you should be able to identify weak username-password combinations in web applications. In this lab, you are going to learn how to perform a dictionary attack on a WordPress web application using Burp Suite.

Objective

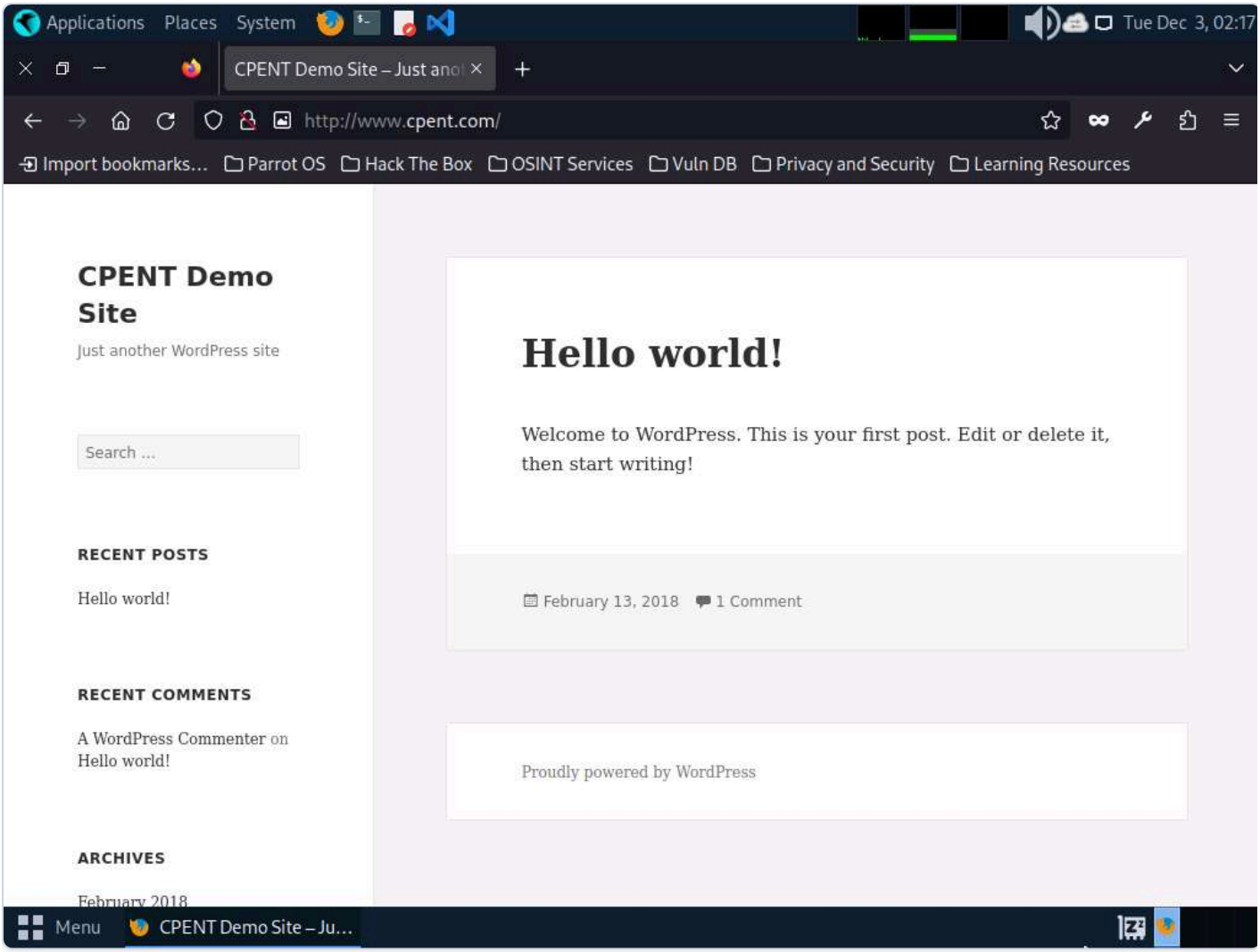
The objective of this lab is to demonstrate how to perform an automated dictionary attack on a WordPress web application using Burp Suite's Intruder tool with custom wordlists.

Task 1: Performing Dictionary Attack on a WordPress Web Application using Burp Suite

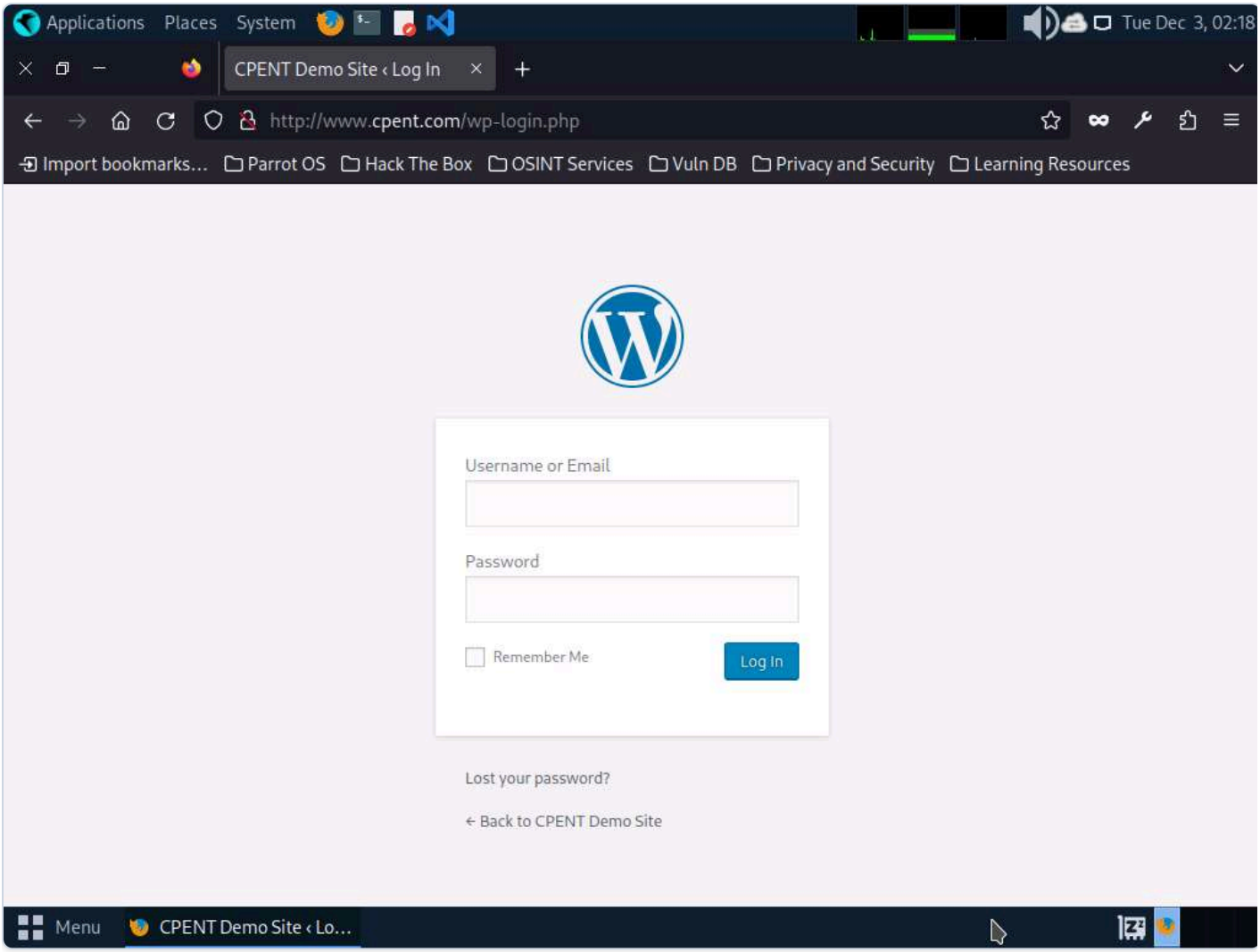
In this task, we target the WordPress login portal at `http://www.cpent.com/wp-login.php`, capture authentication requests using Burp Suite Proxy, configure a Cluster Bomb attack using Intruder, and execute a multi-payload dictionary attack using wordlists located in `CPENTv2 Pen Testing Resources/Wordlists/`.

Lab Tasks

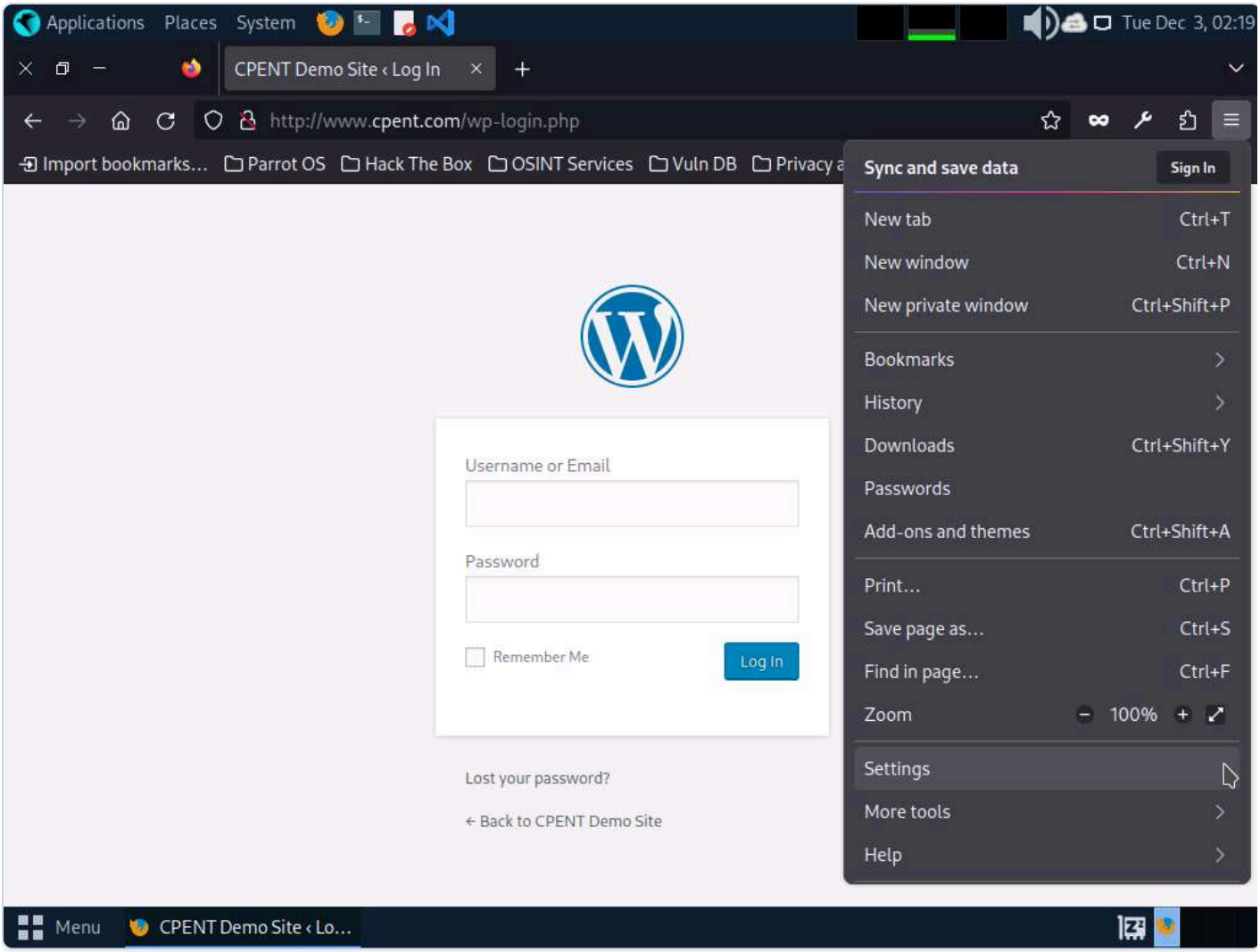
1. Click **Parrot Security**. Type **toor** in the Password field and press Enter.
2. *(If you are already logged in, skip to step 2.)*
3. Launch a web browser, type **http://www.cpent.com**, and press Enter. CPENT Demo Site appears.



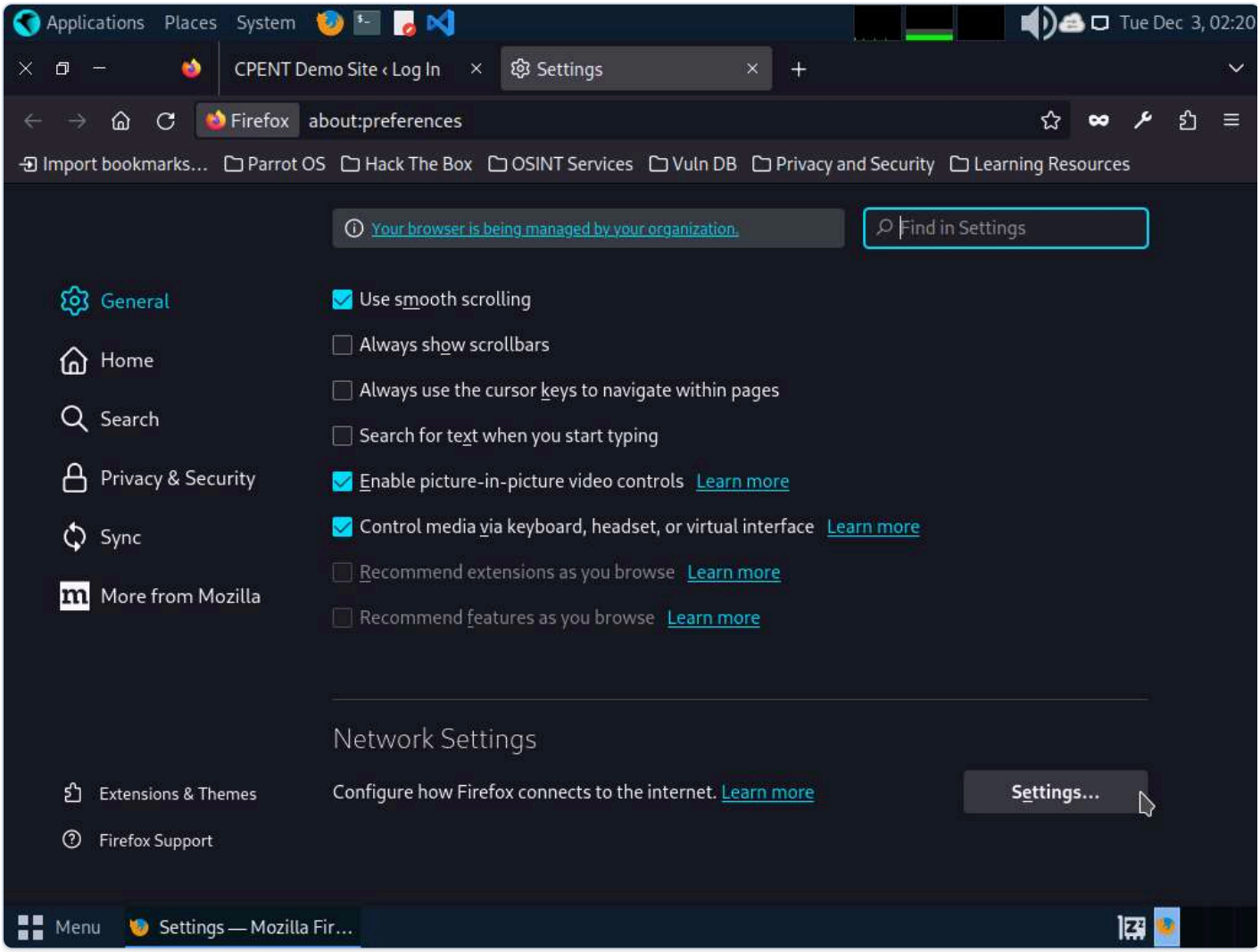
1. Type **http://www.cpent.com/wp-login.php** in the address bar and press Enter to load the login page.



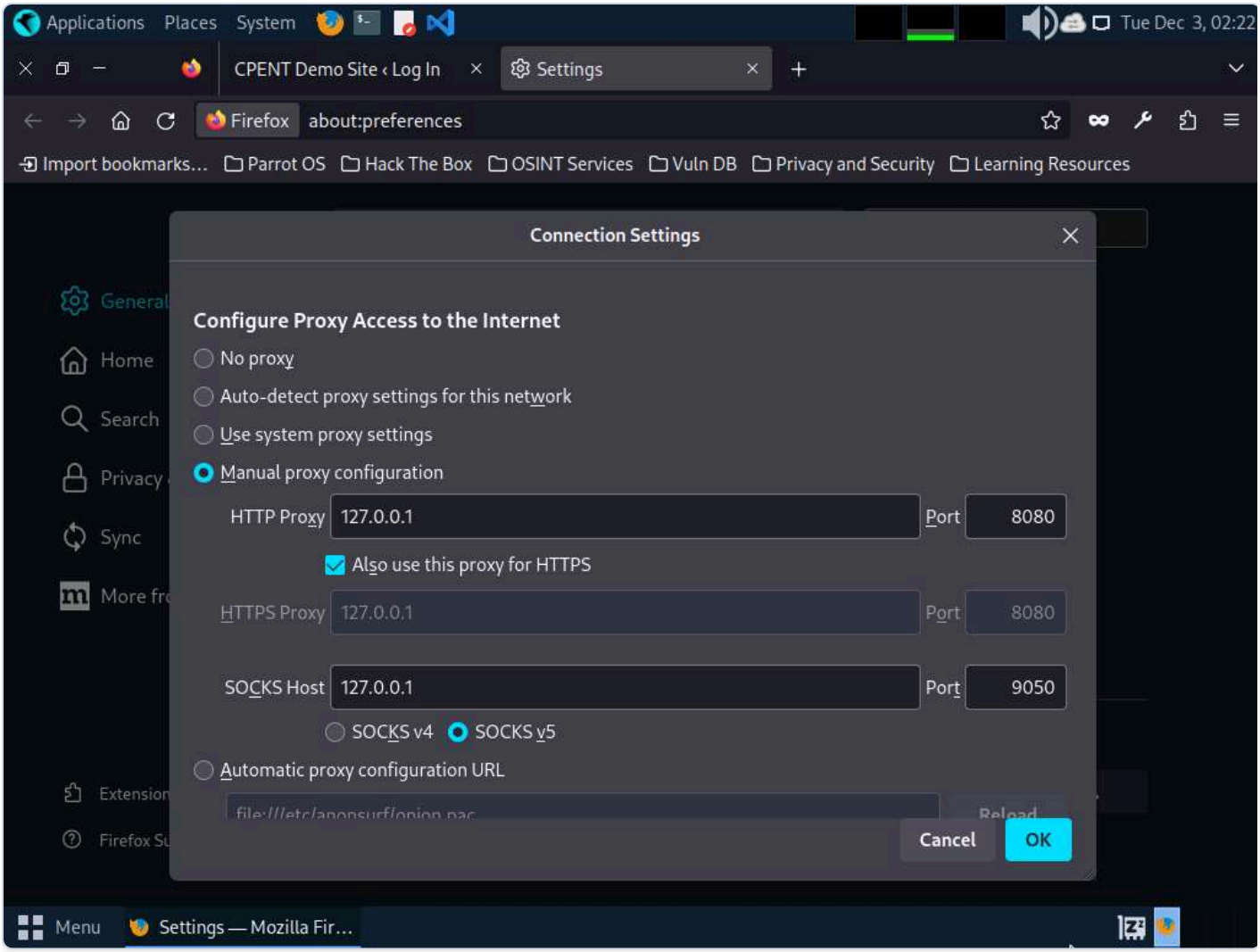
1. Open the Firefox menu and click **Settings**.



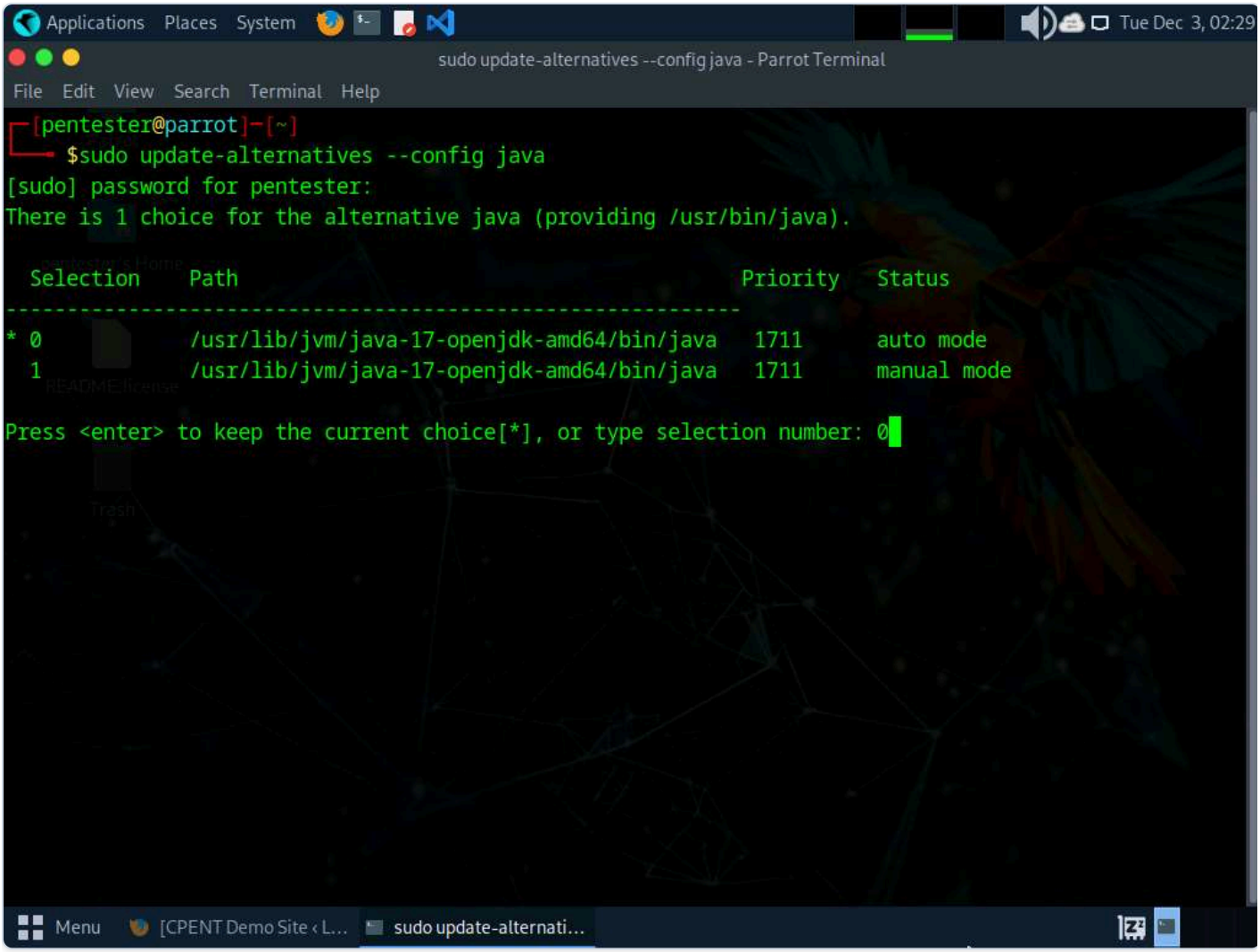
1. Under **General** settings, scroll down and click **Settings** under **Network Settings**.



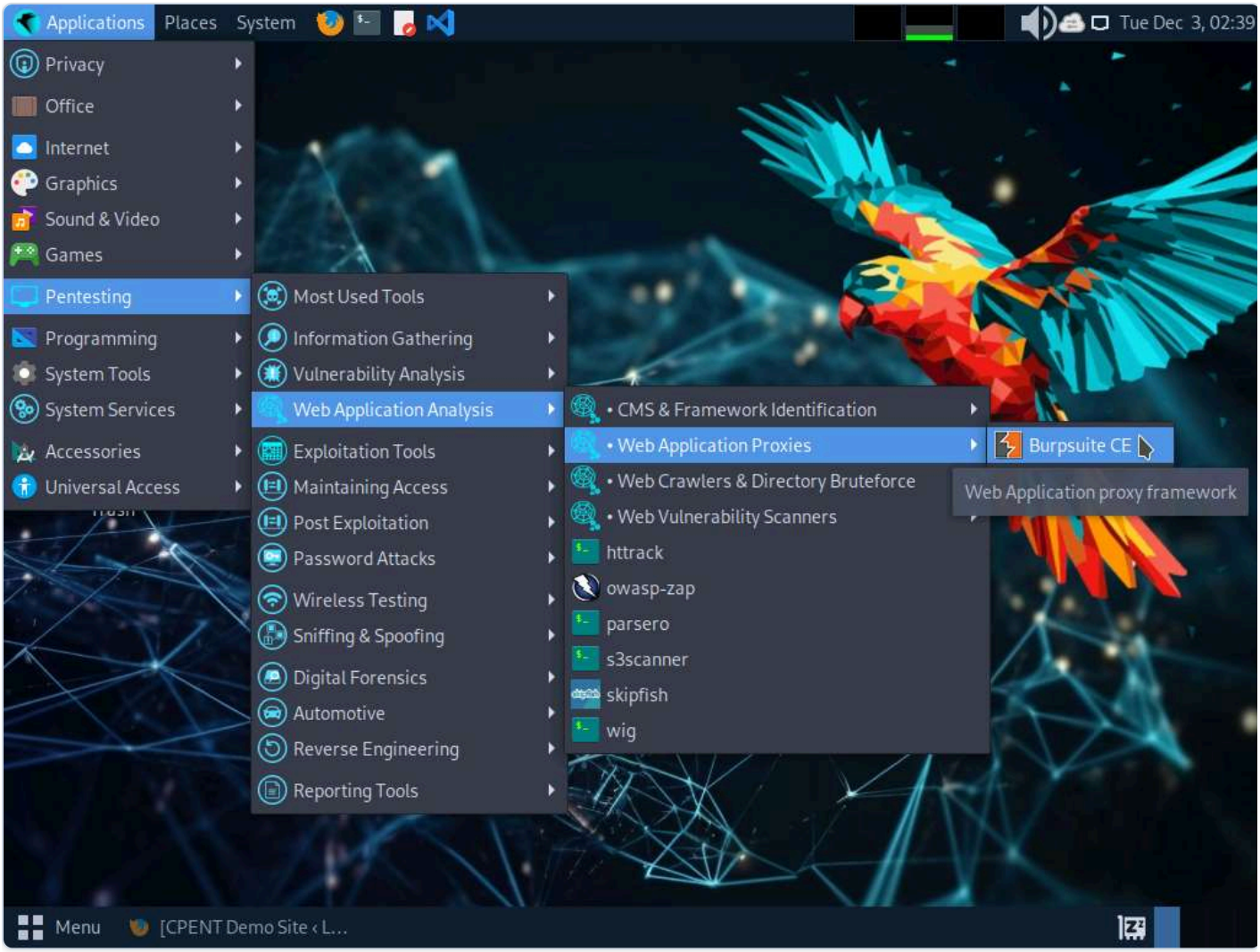
1. In Connection Settings, select **Manual proxy configuration**. Set HTTP Proxy to **127.0.0.1**, Port to **8080**, check **Also use this proxy for HTTPS**, and click **OK**.



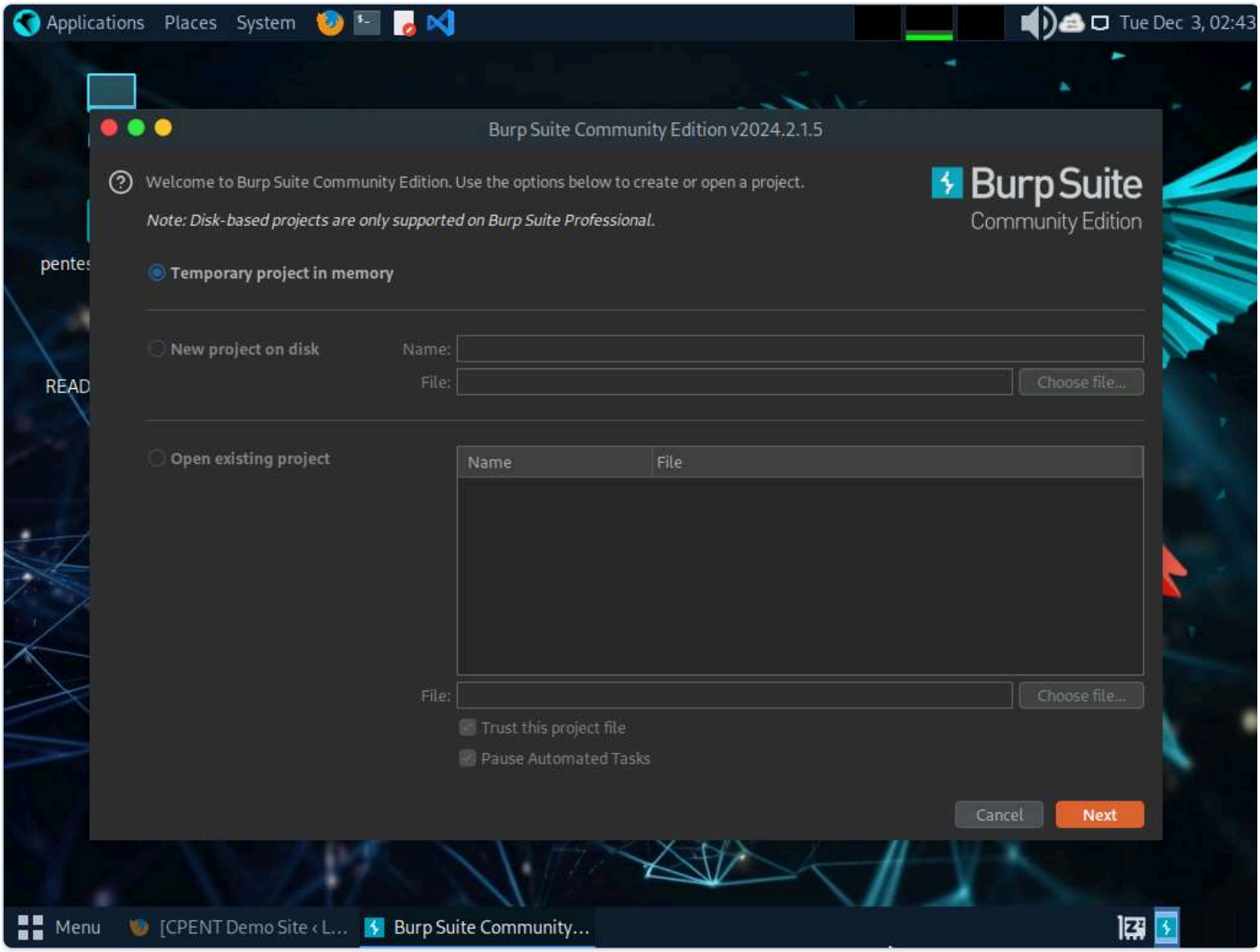
1. Close the Settings tab and minimize the web browser.
2. Open a terminal and run **sudo update-alternatives --config java**. Type password **toor**. Select choice **0** and press Enter. Close the terminal.



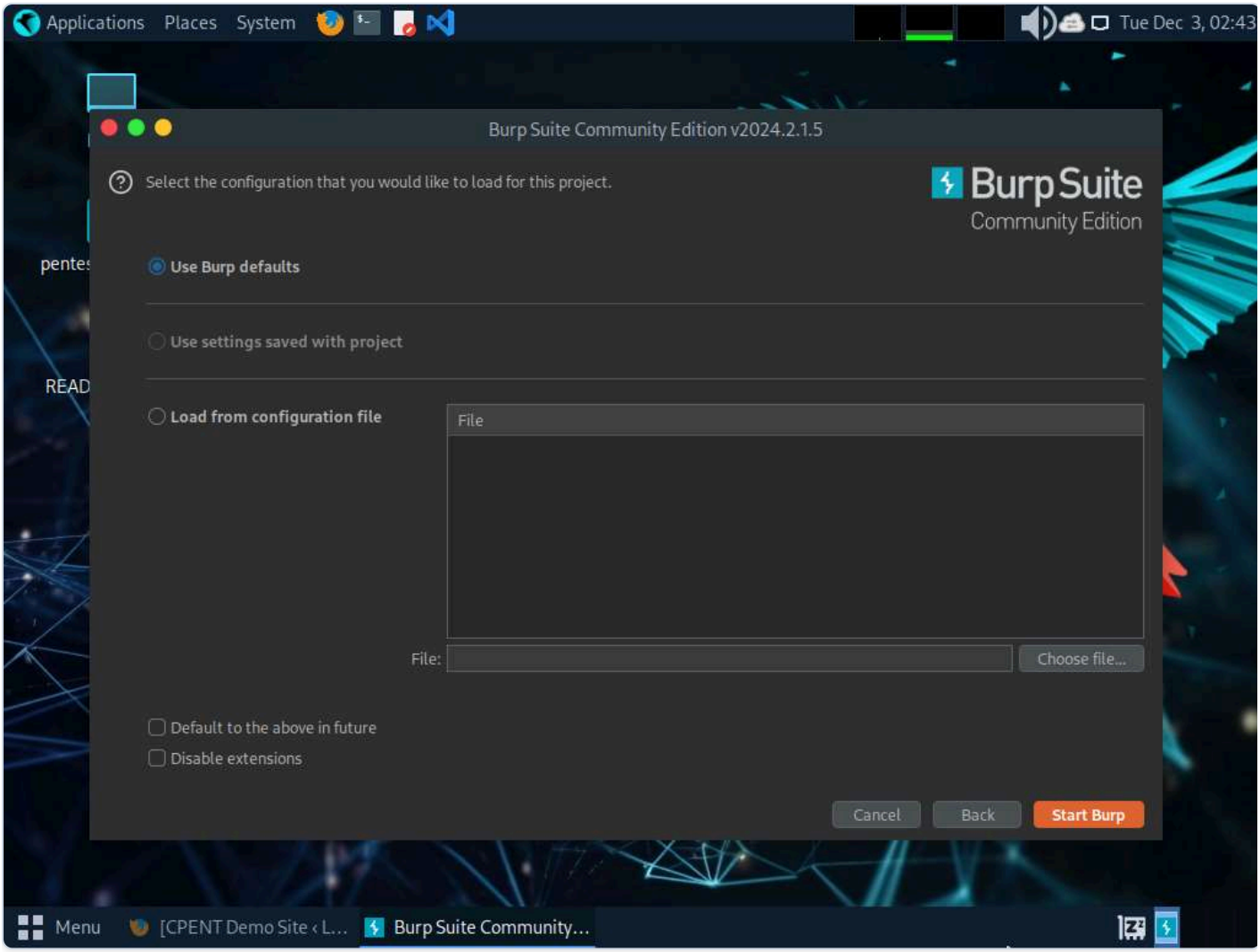
1. Launch Burp Suite from **Applications** --> **Pentesting** --> **Web Application Analysis** --> **Web Application Proxies** --> **Burpsuite**.



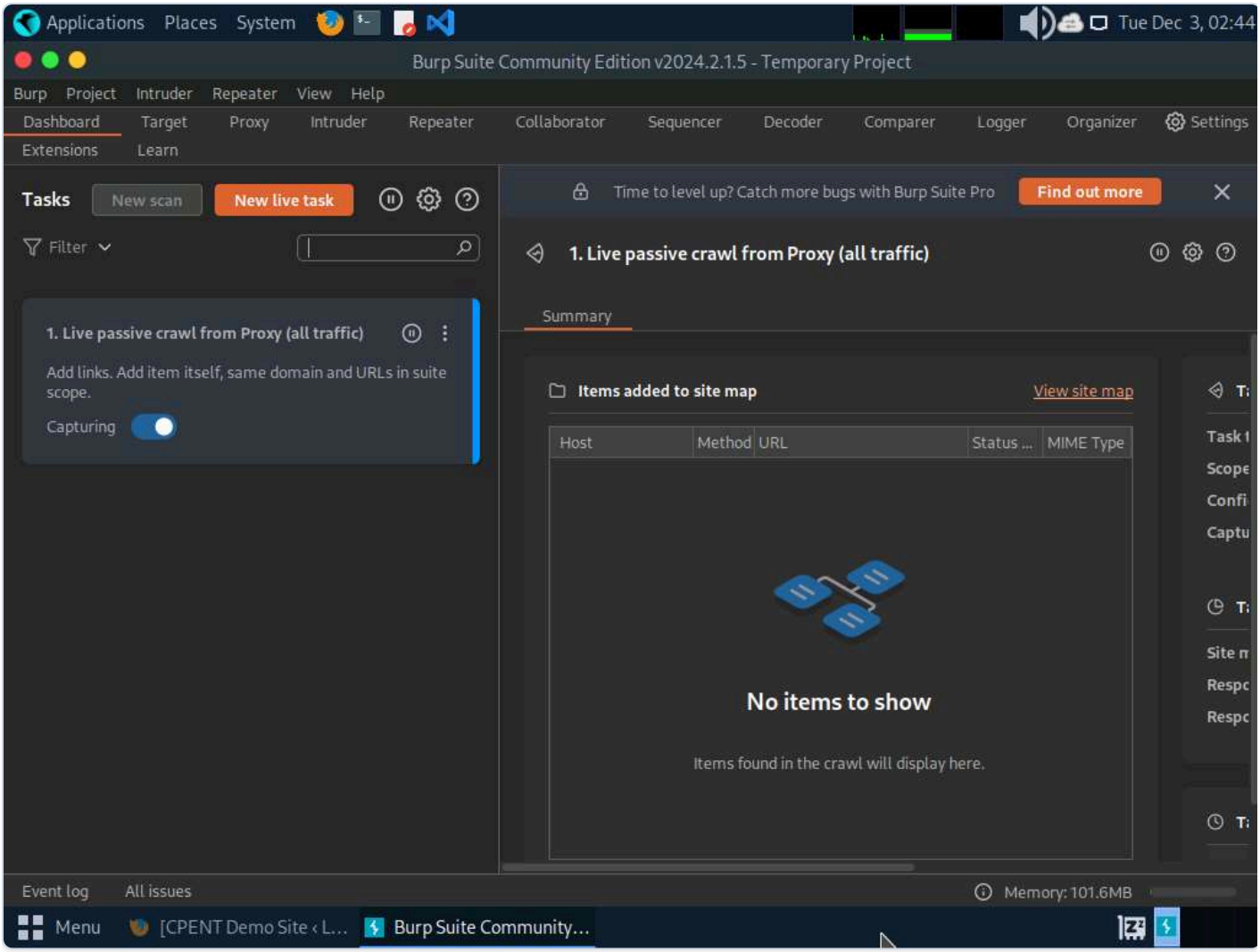
1. If prompted for password, enter **toor** and click OK. Accept the License Agreement and click **OK** on the version pop-up.
2. Keep **Temporary project** selected and click **Next**. Click **Close** if an update prompt appears.



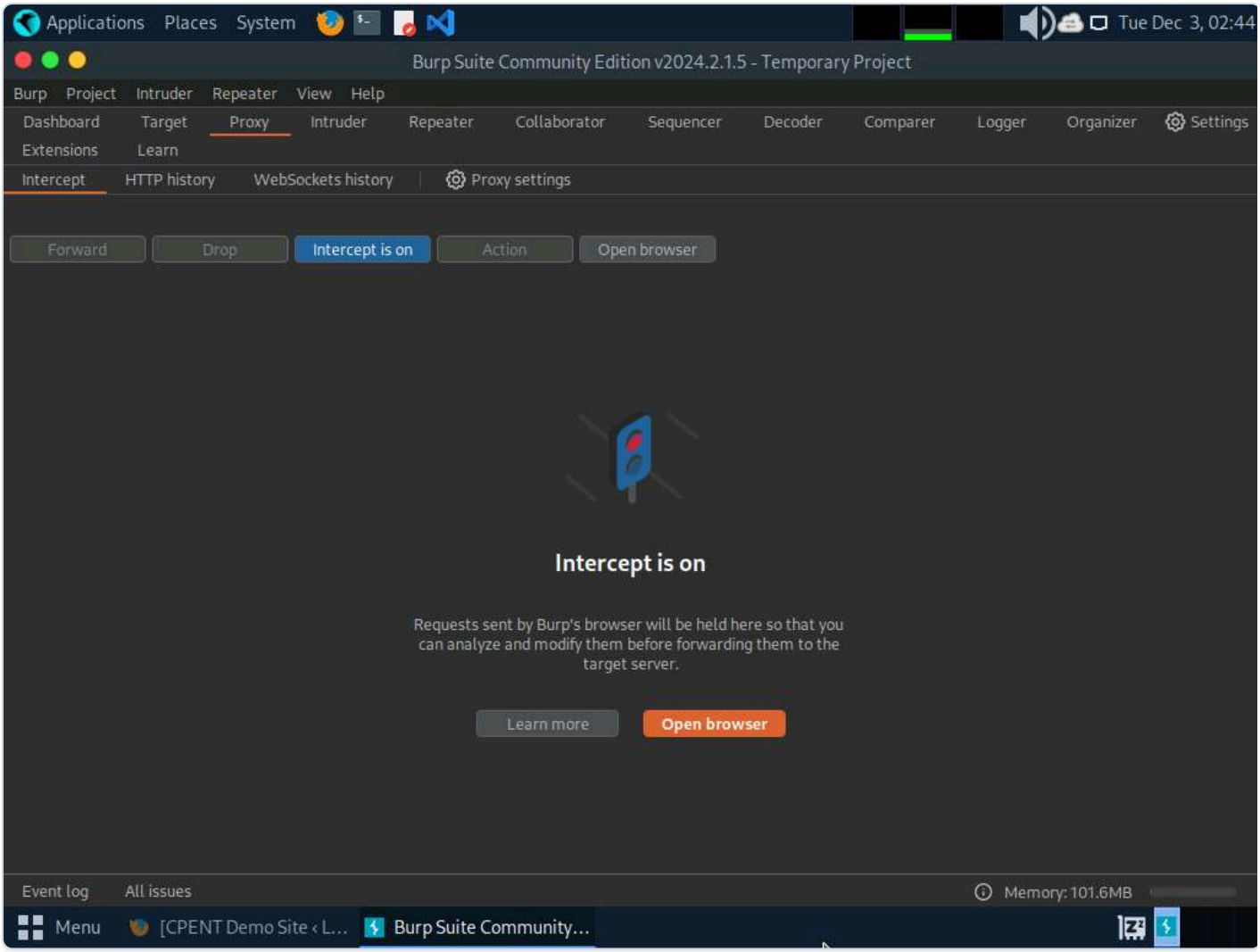
1. Select **Use Burp defaults** and click **Start Burp**.



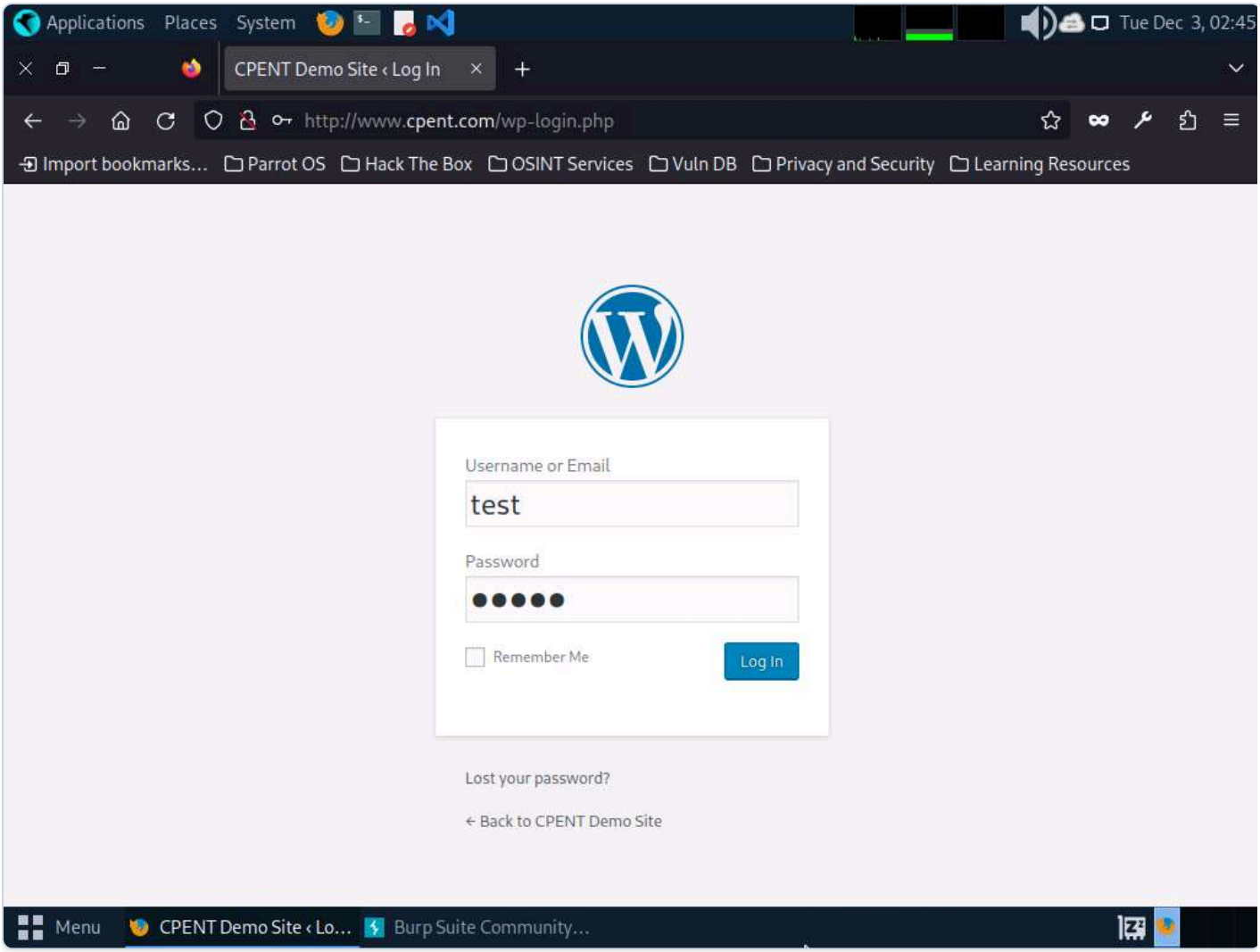
1. Click the **Proxy** tab in Burp Suite.



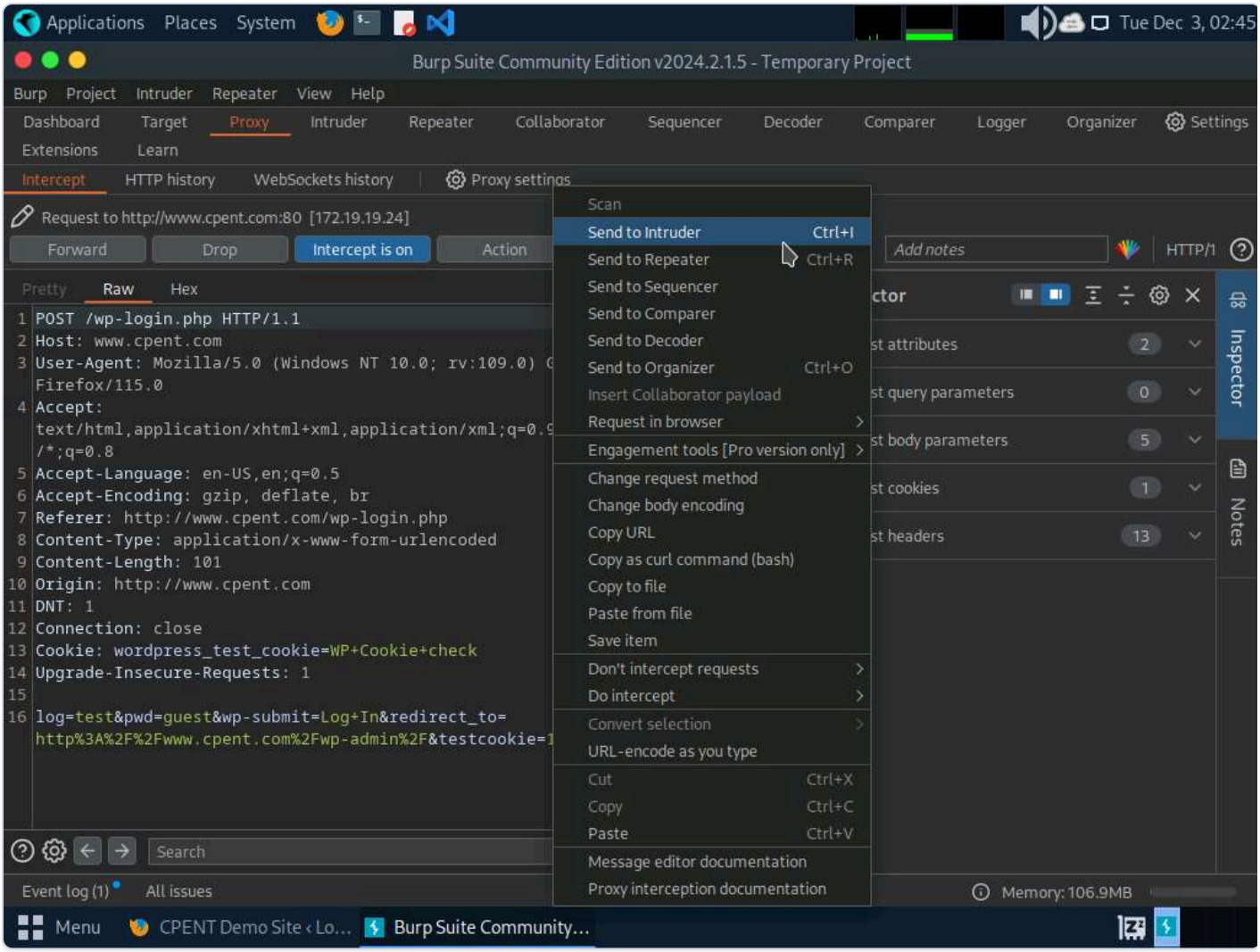
1. In the **Intercept** tab, verify that **Intercept is on** is active.



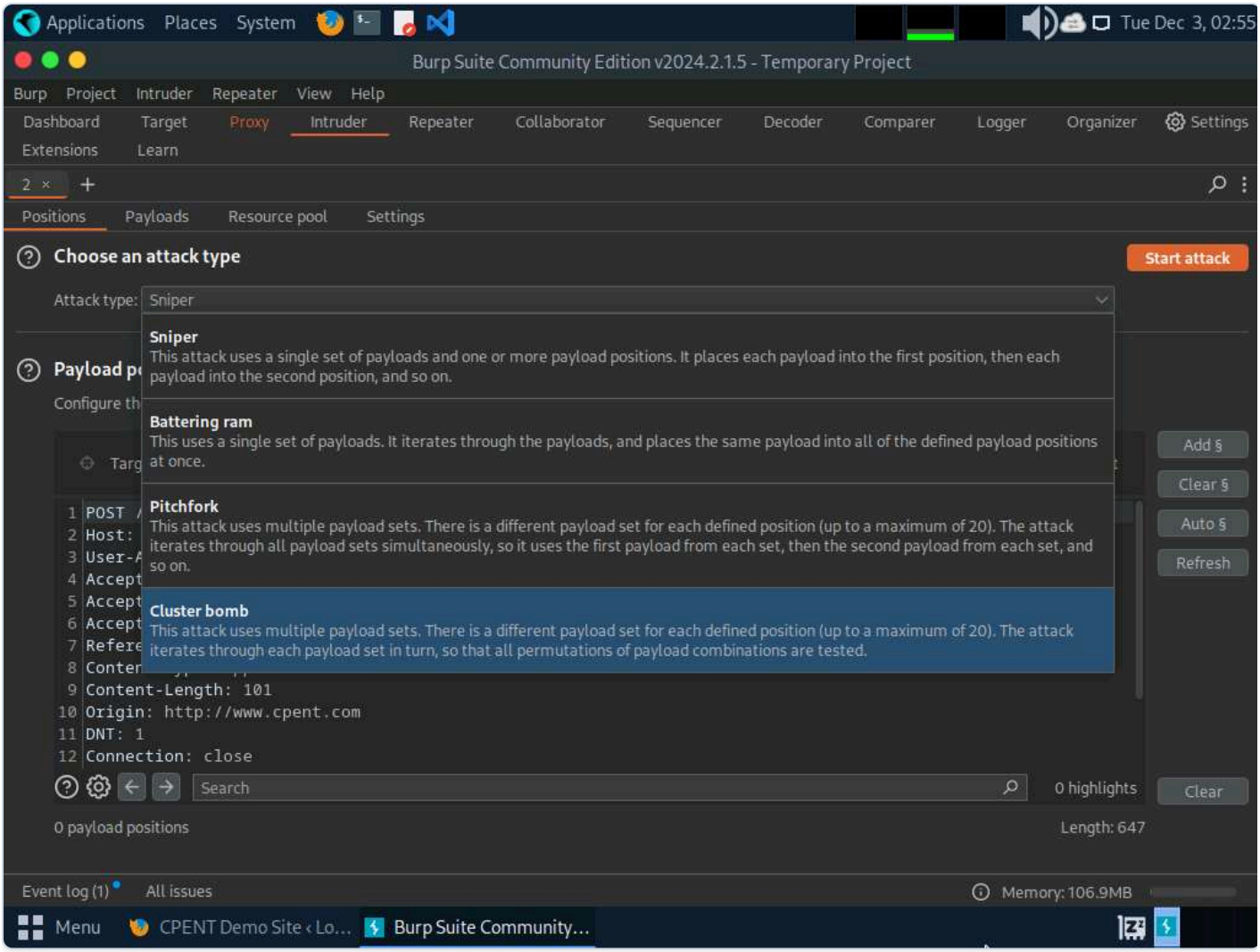
1. Maximize the web browser on the WordPress login page. Enter test credentials: username **test** and password **guess**, then click **Log In**.



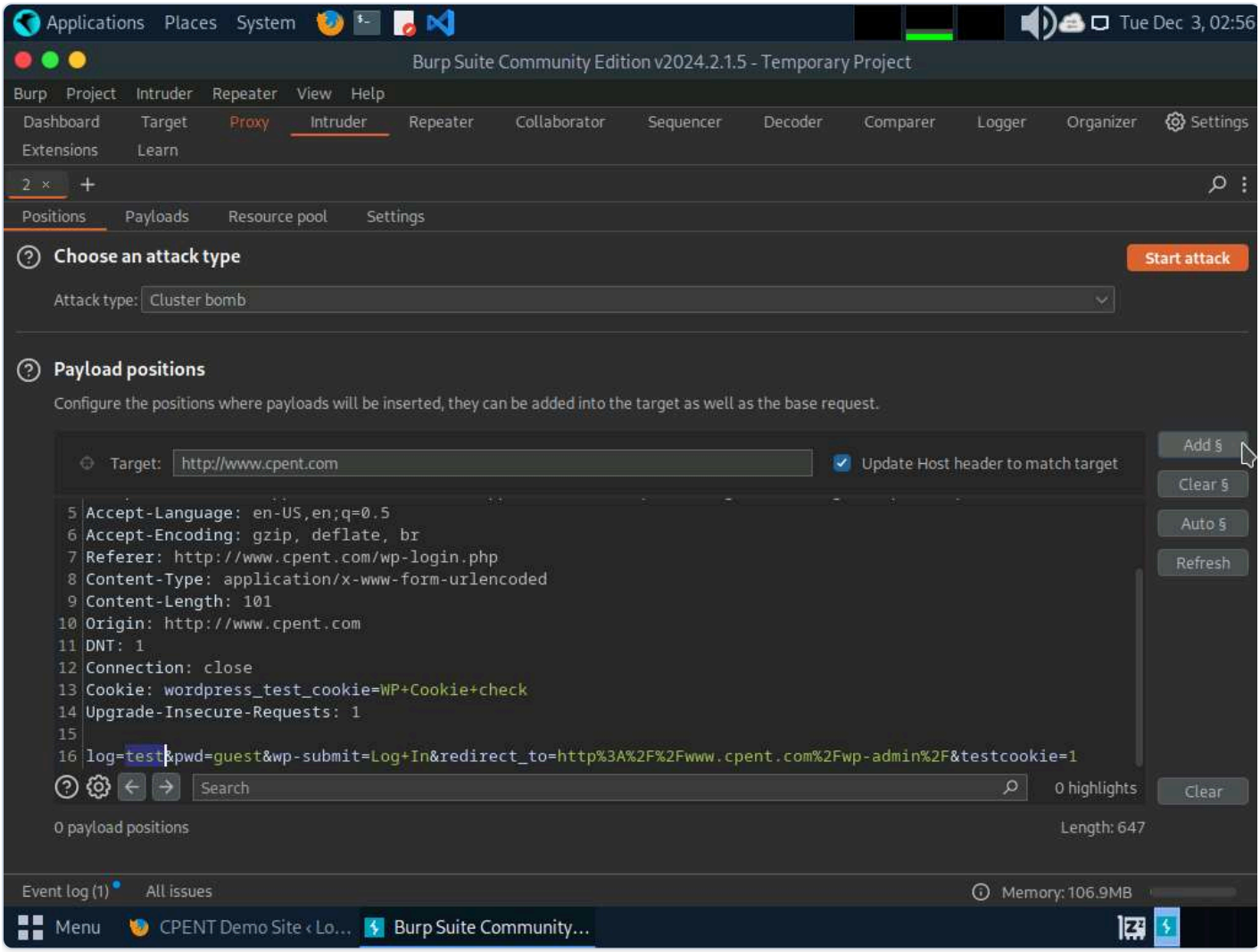
1. In Burp Suite, observe the intercepted HTTP POST request. Right-click the request and select **Send to Intruder**.



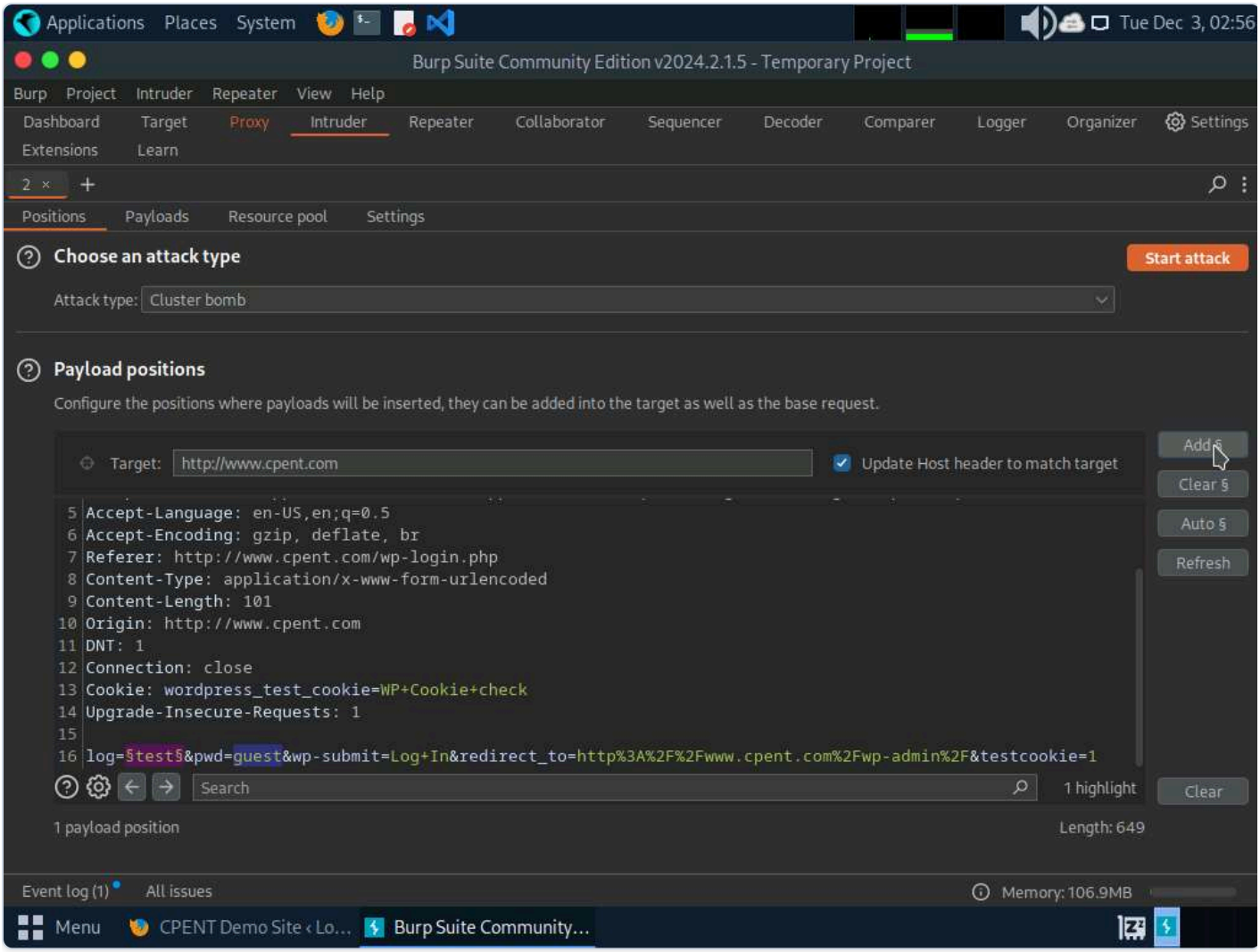
1. Switch to the **Intruder** tab and select **Cluster bomb** from the Attack type drop-down menu.



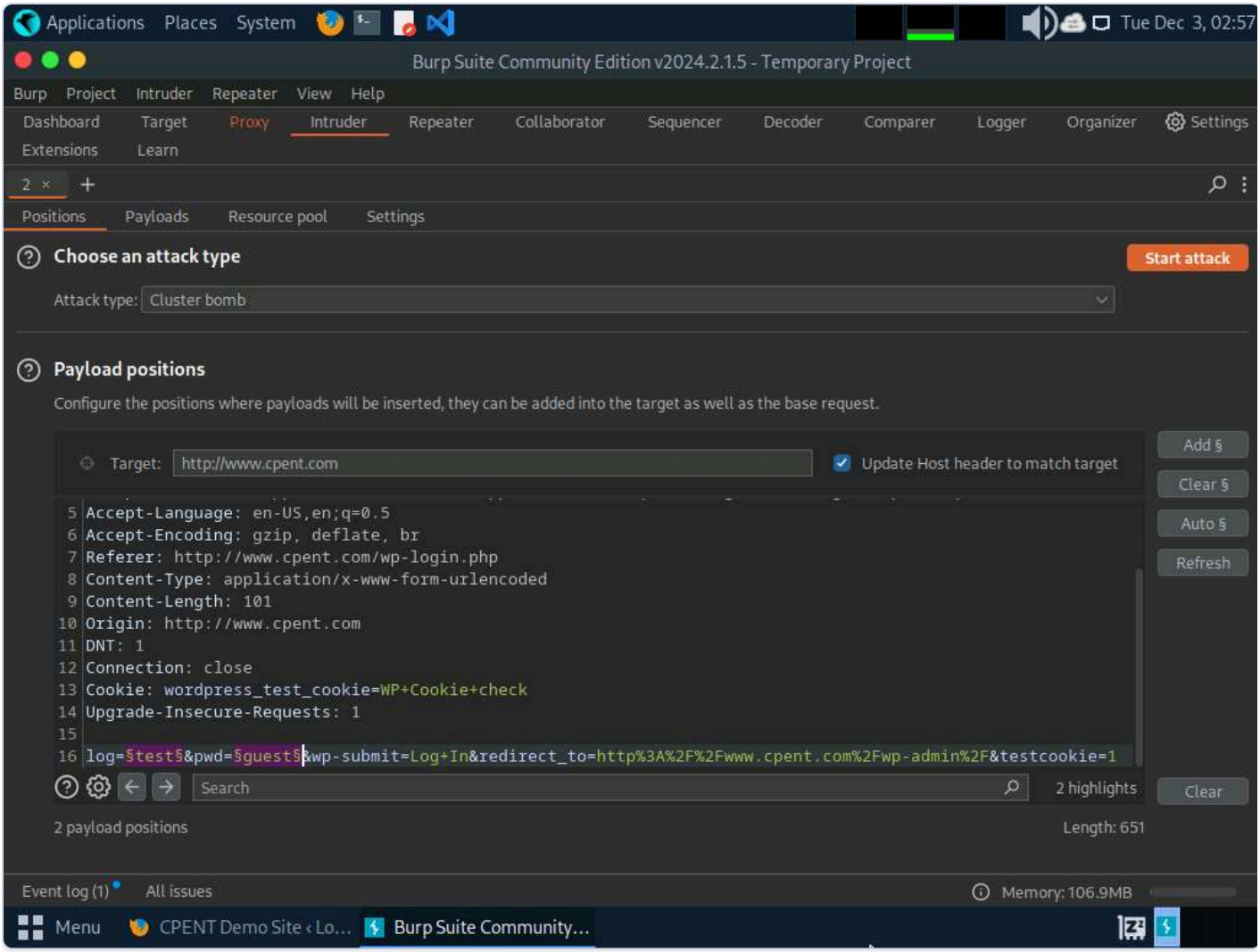
1. Highlight `test` in the request body and click **Add §** to set the username position.



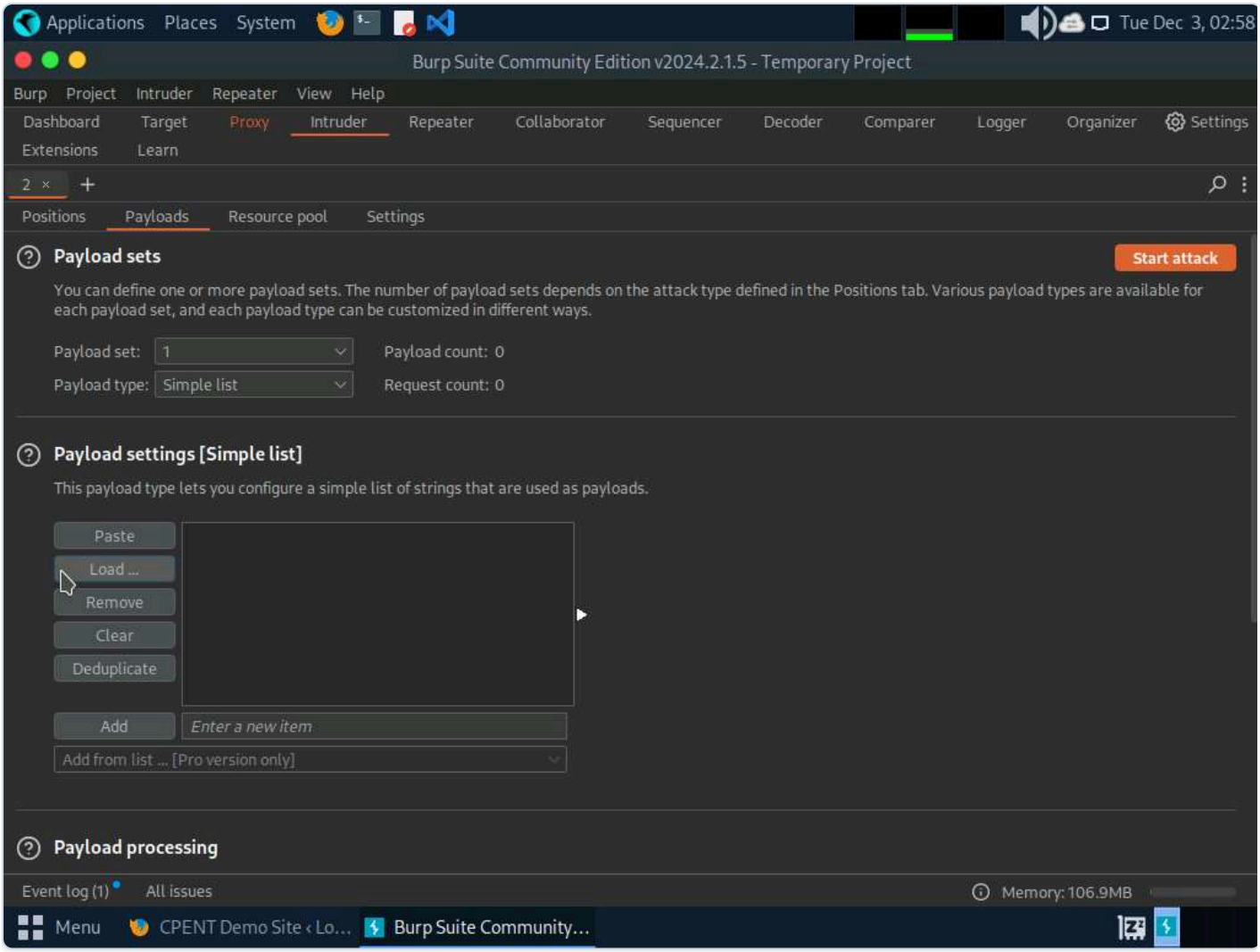
1. Highlight `guess` in the request body and click **Add §** to set the password position.



1. Click the **Payloads** tab.

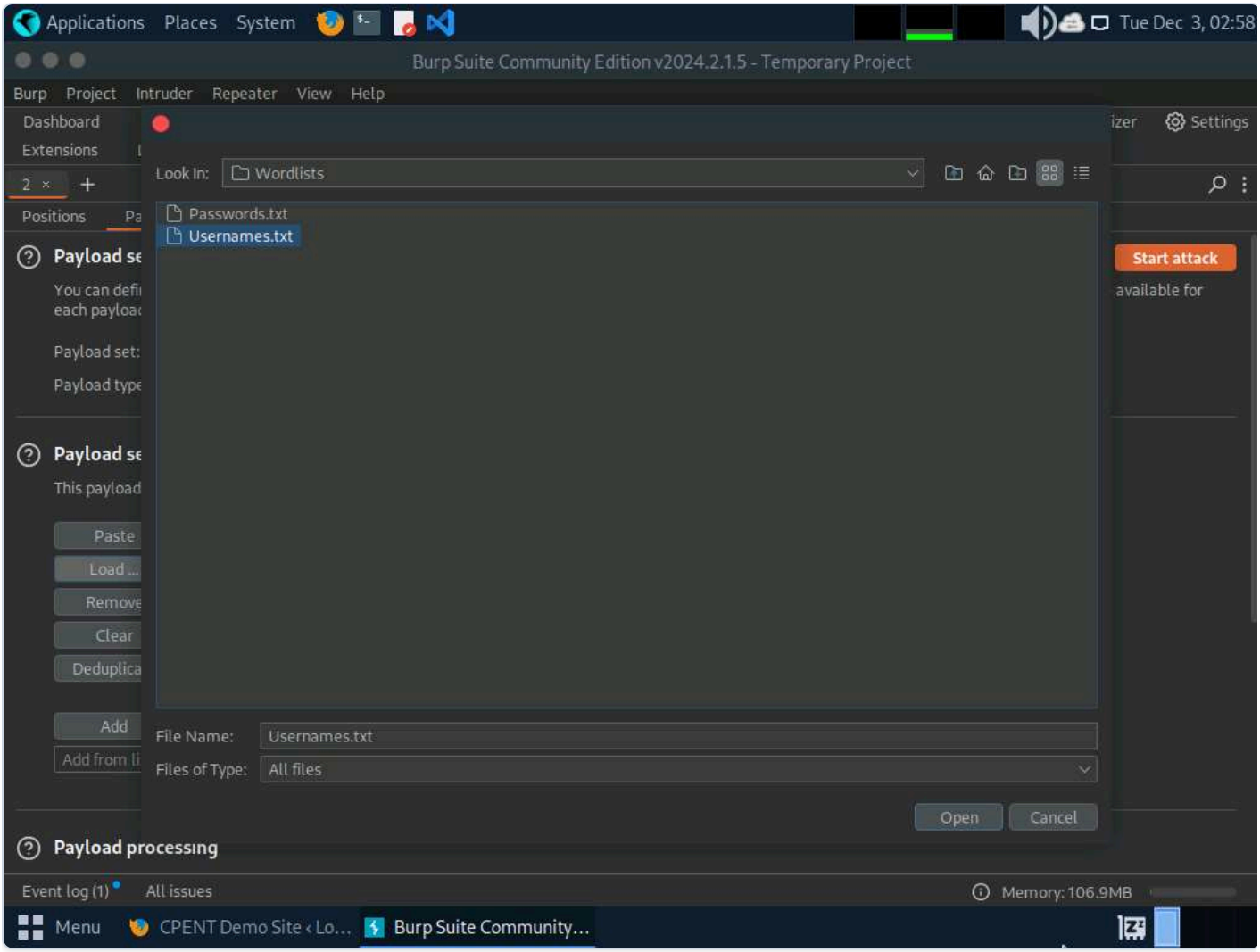


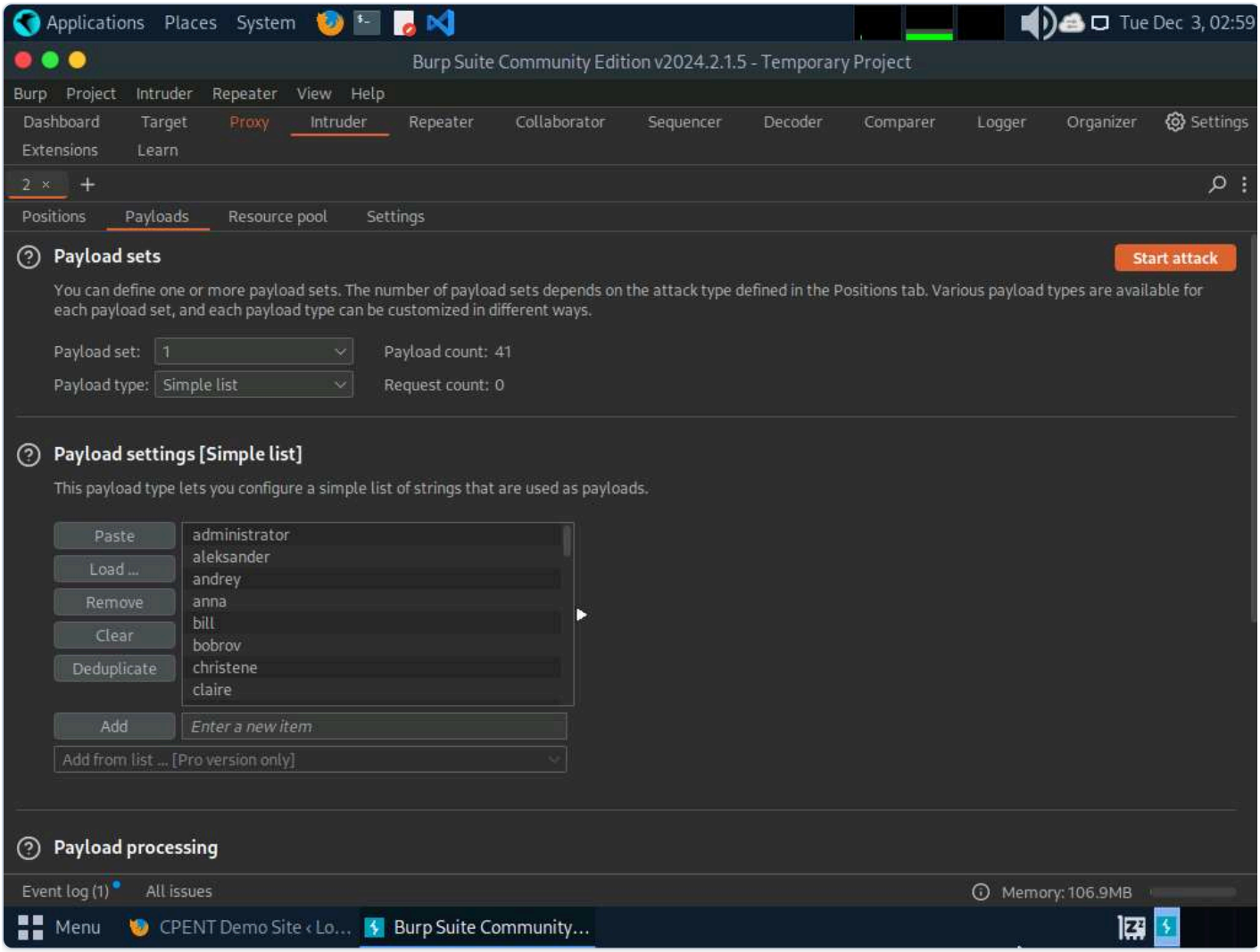
1. With **Payload set 1** selected, click **Load ...**.



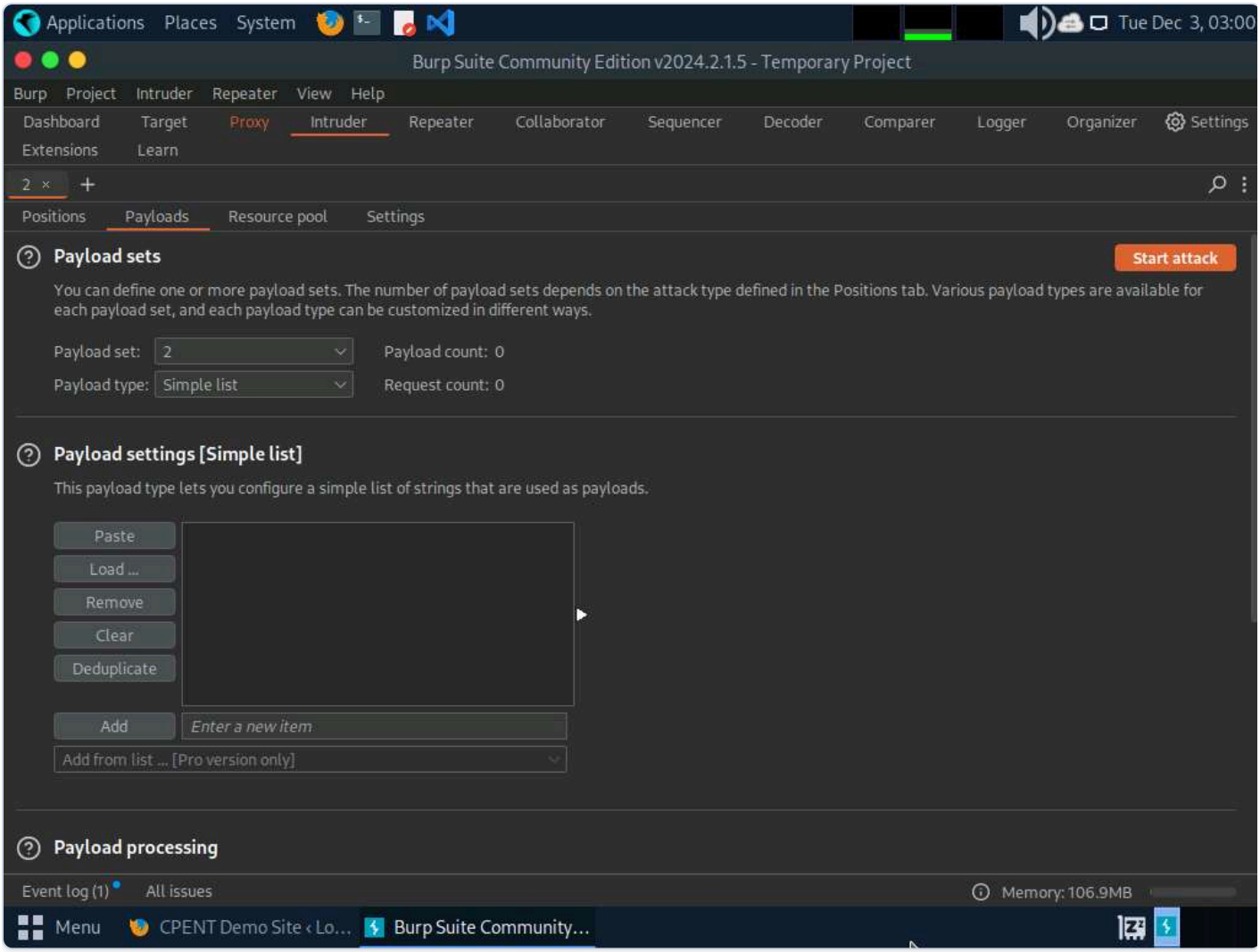
1. In the file chooser, navigate to `CPENTv2 Pen Testing Resources/Wordlists/` (or VM path `/home/pentester/Wordlists`), select **Usernames.txt**, and click **Open**.

> **TIP:** 📁 **Local Repository Asset**: Inside your local vault, this wordlist is located at: `CPENTv2 Pen Testing Resources/Wordlists/Usernames.txt`


Applications
Places
System
Tue Dec 3, 02:58
Burp Suite Community Edition v2024.2.1.5 - Temporary Project
Burp
Project
Intruder
Repeater
View
Help
Dashboard
Extensions
Settings
Look In:
Wordlists
Passwords.txt
Usernames.txt
Start attack
available for
Payload set:
Payload type
Paste
Load ...
Remove
Clear
Add
File Name:
Usernames.txt
Files of Type:
All files
Open
Cancel
Payload processing
Event log (1)
All issues
Memory: 106.9MB
Menu
CPENT Demo Site ‹ Lo...
Burp Suite Community...

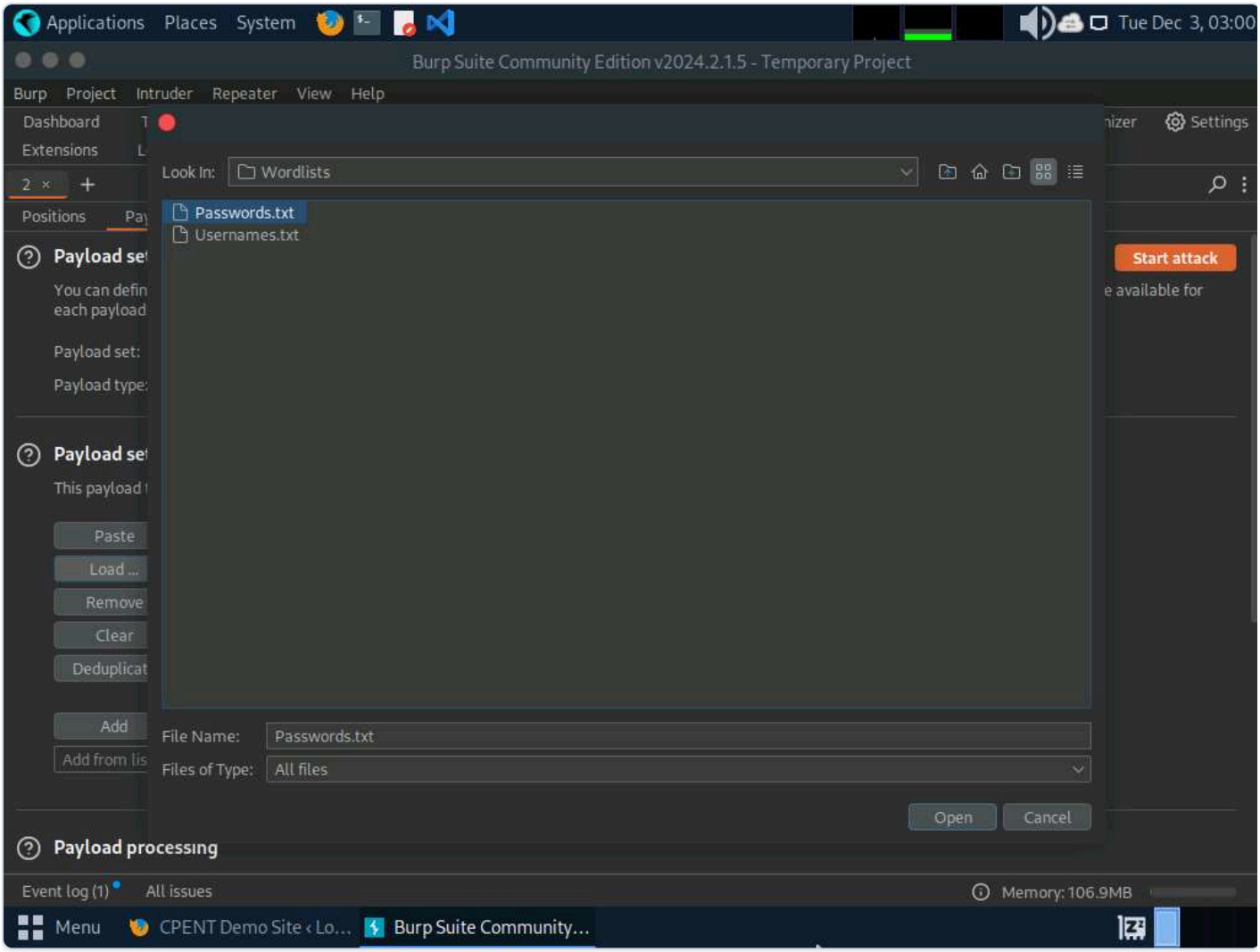


1. Select **Payload set 2** from the drop-down list and click **Load ...**.

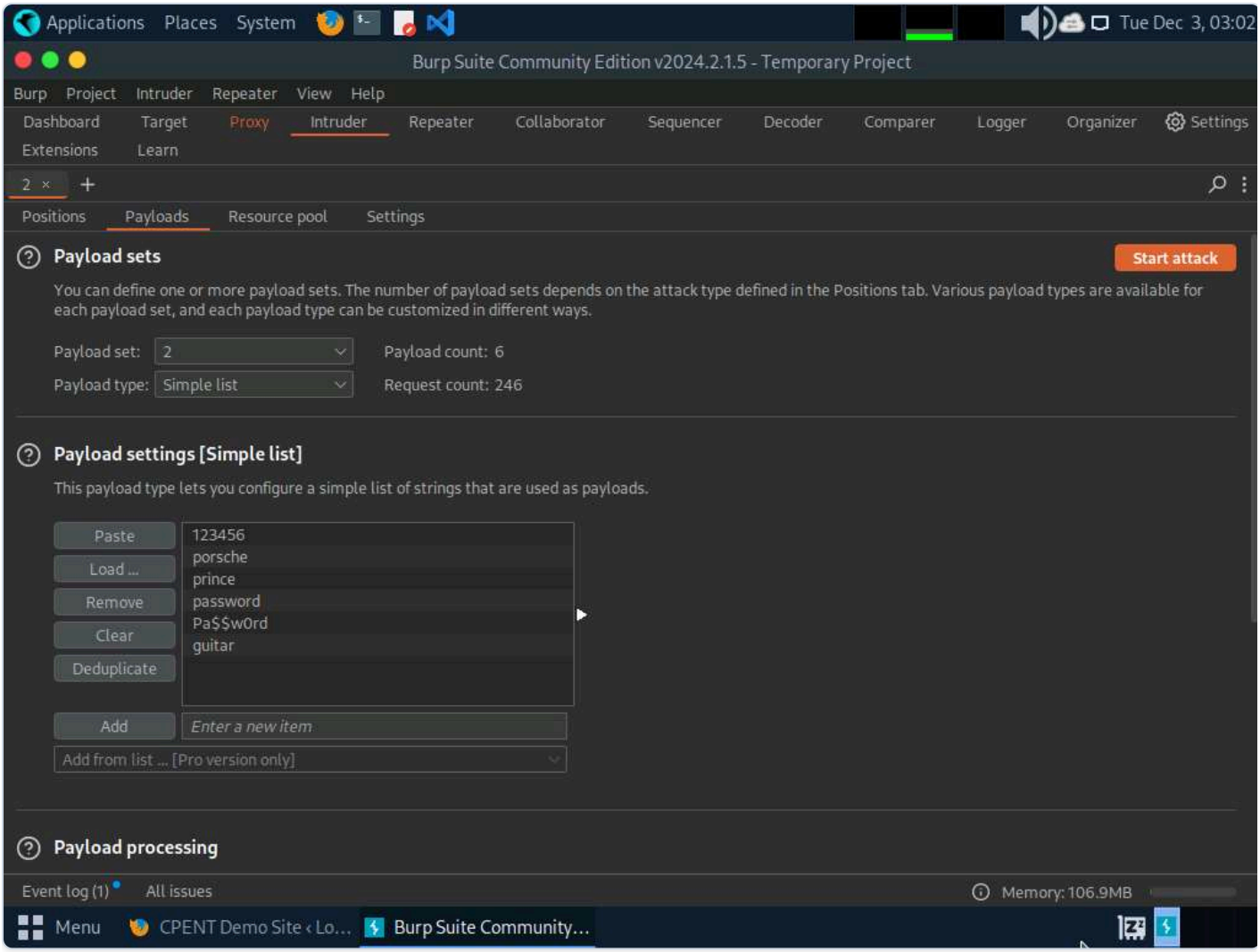


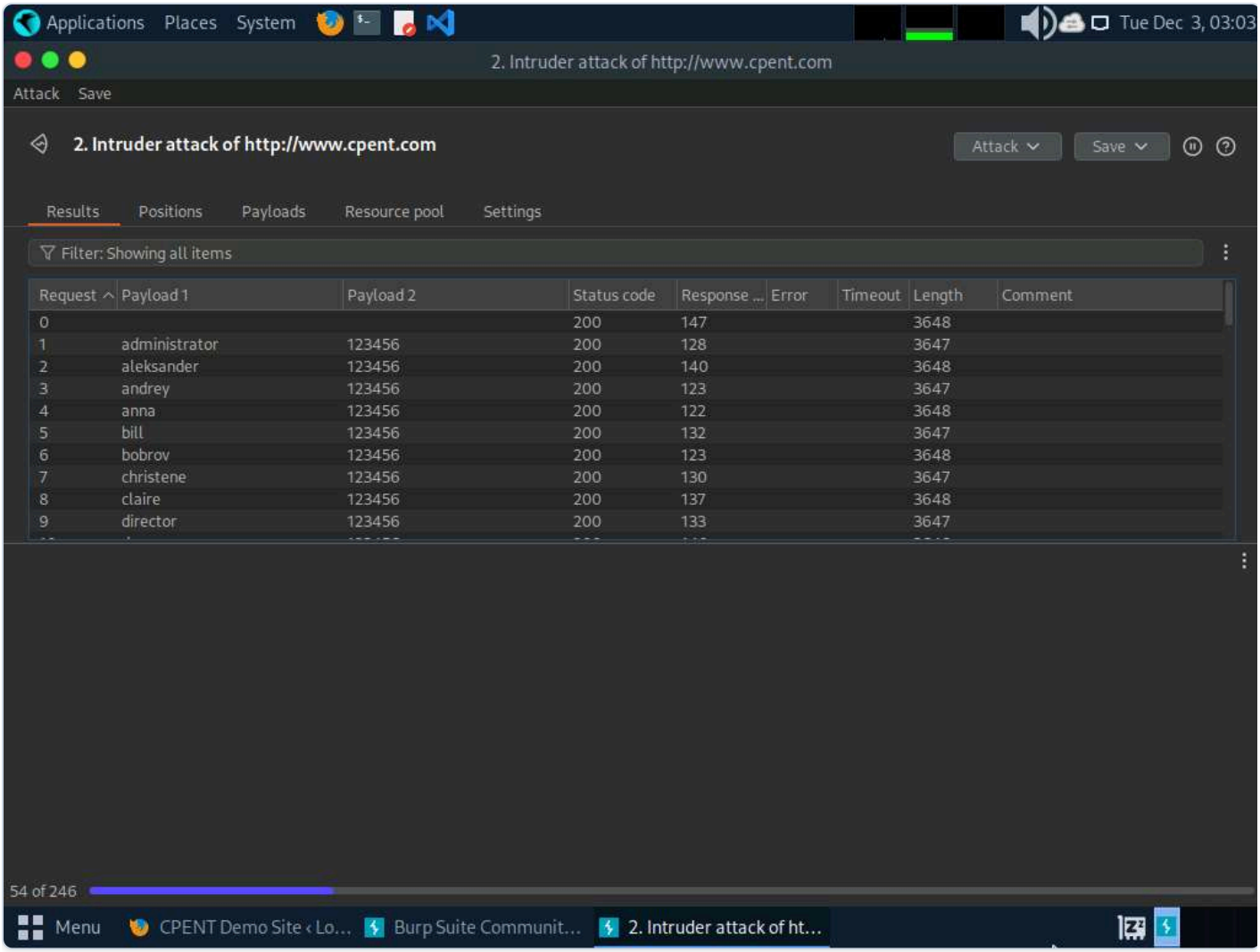
1. Navigate to `CPENTv2 Pen Testing Resources/Wordlists/` (or VM path `/home/pentester/Wordlists`), select **Passwords.txt**, and click **Open**.

> **TIP:** 📁 **Local Repository Asset**: Inside your local vault, this wordlist is located at: `CPENTv2 Pen Testing Resources/Wordlists/Passwords.txt`

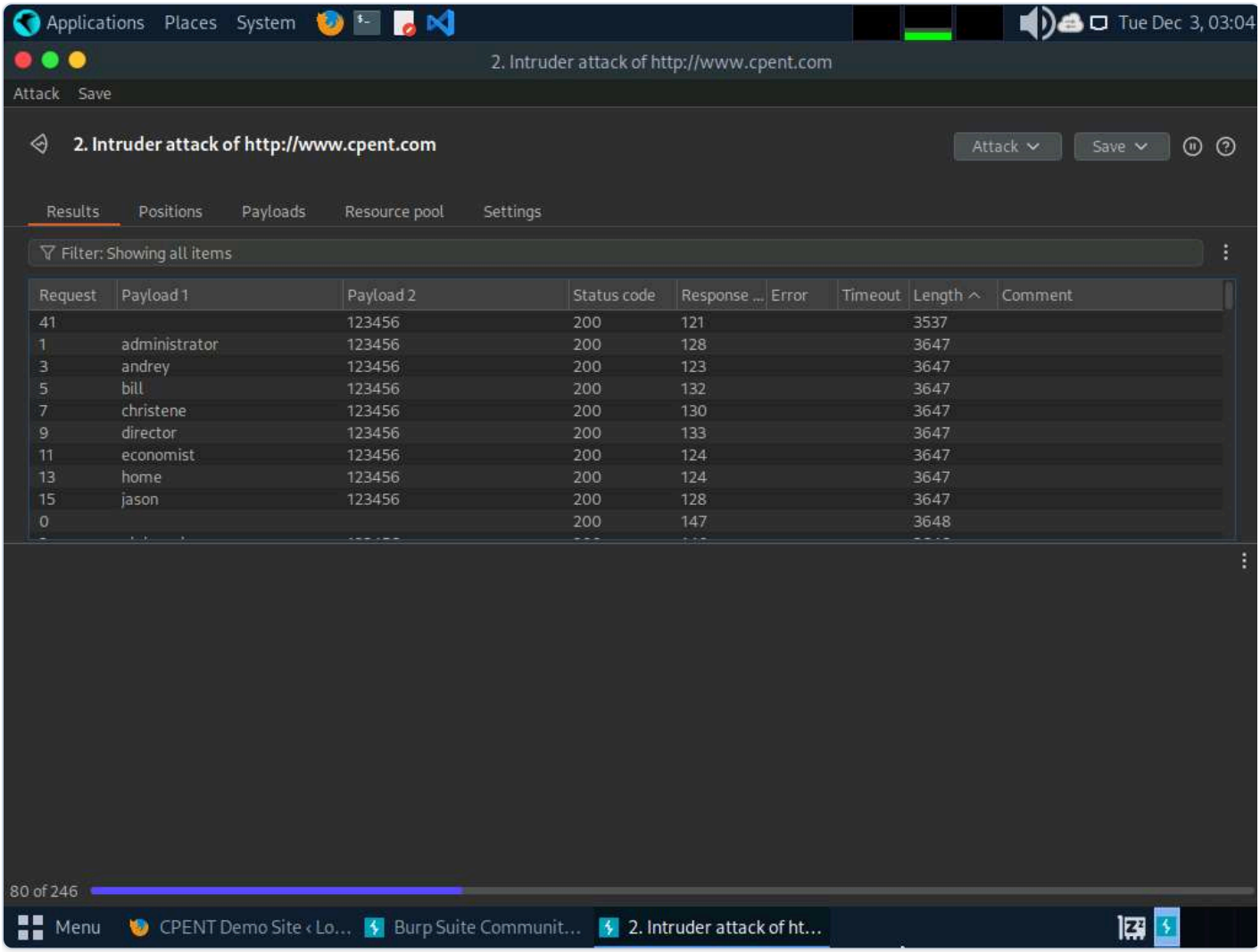


1. Click **Start attack**. Click **OK** on the Burp Intruder prompt.

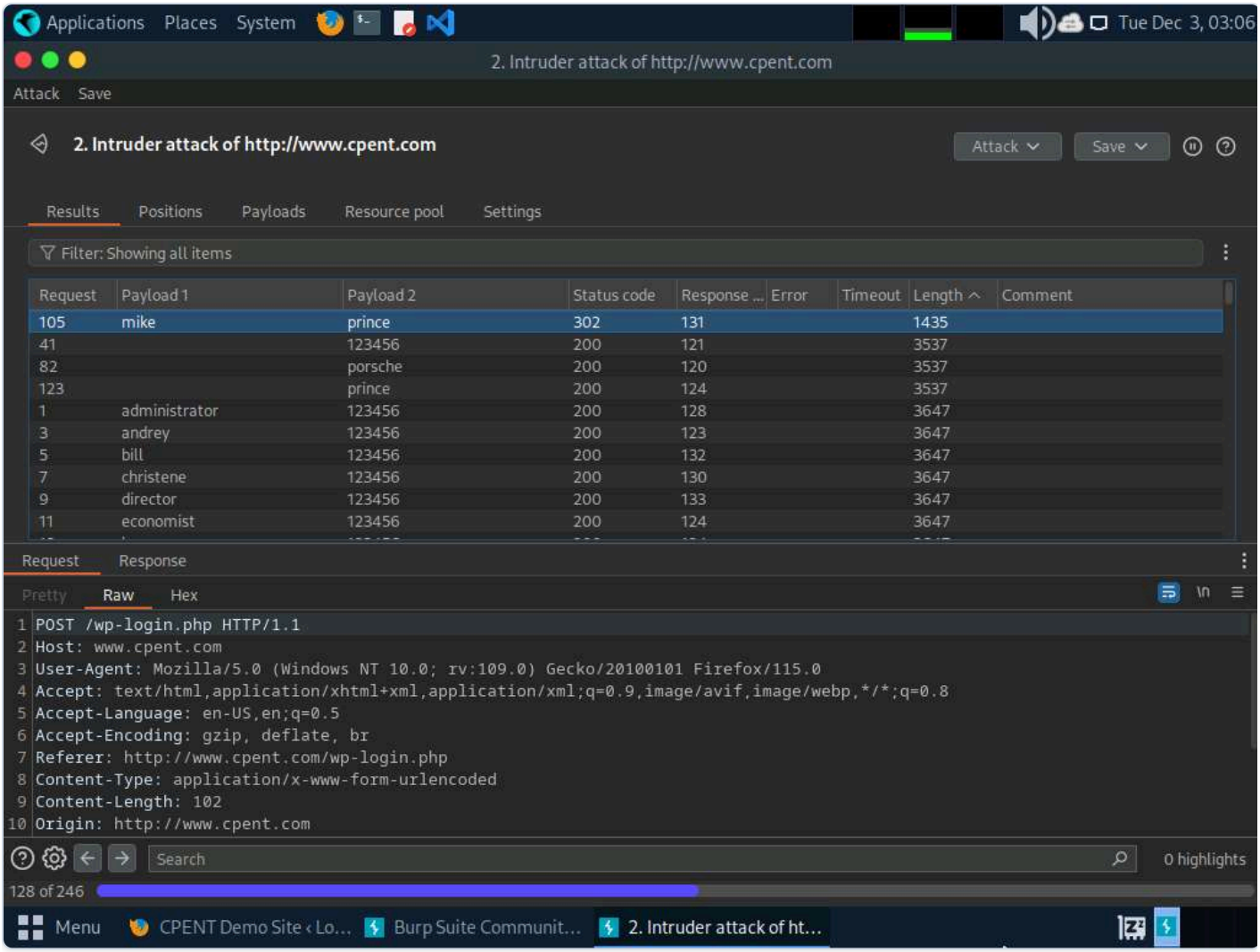

Applications Places System
Tue Dec 3, 03:02
Burp Suite Community Edition v2024.2.1.5 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings
Extensions Learn
2 ×
Positions Payloads Resource pool Settings
Payload sets
Start attack
You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.
Payload set: 2
Payload count: 6
Payload type: Simple list
Request count: 246
Payload settings [Simple list]
This payload type lets you configure a simple list of strings that are used as payloads.
Paste
Load ...
Remove
Clear
Deduplicate
123456
porsche
prince
password
Pa$$w0rd
guitar
Add
Enter a new item
Add from list ... [Pro version only]
Payload processing
Event log (1)
All issues
Memory: 106.9MB
Menu
CPENT Demo Site ‹ Lo...
Burp Suite Community...



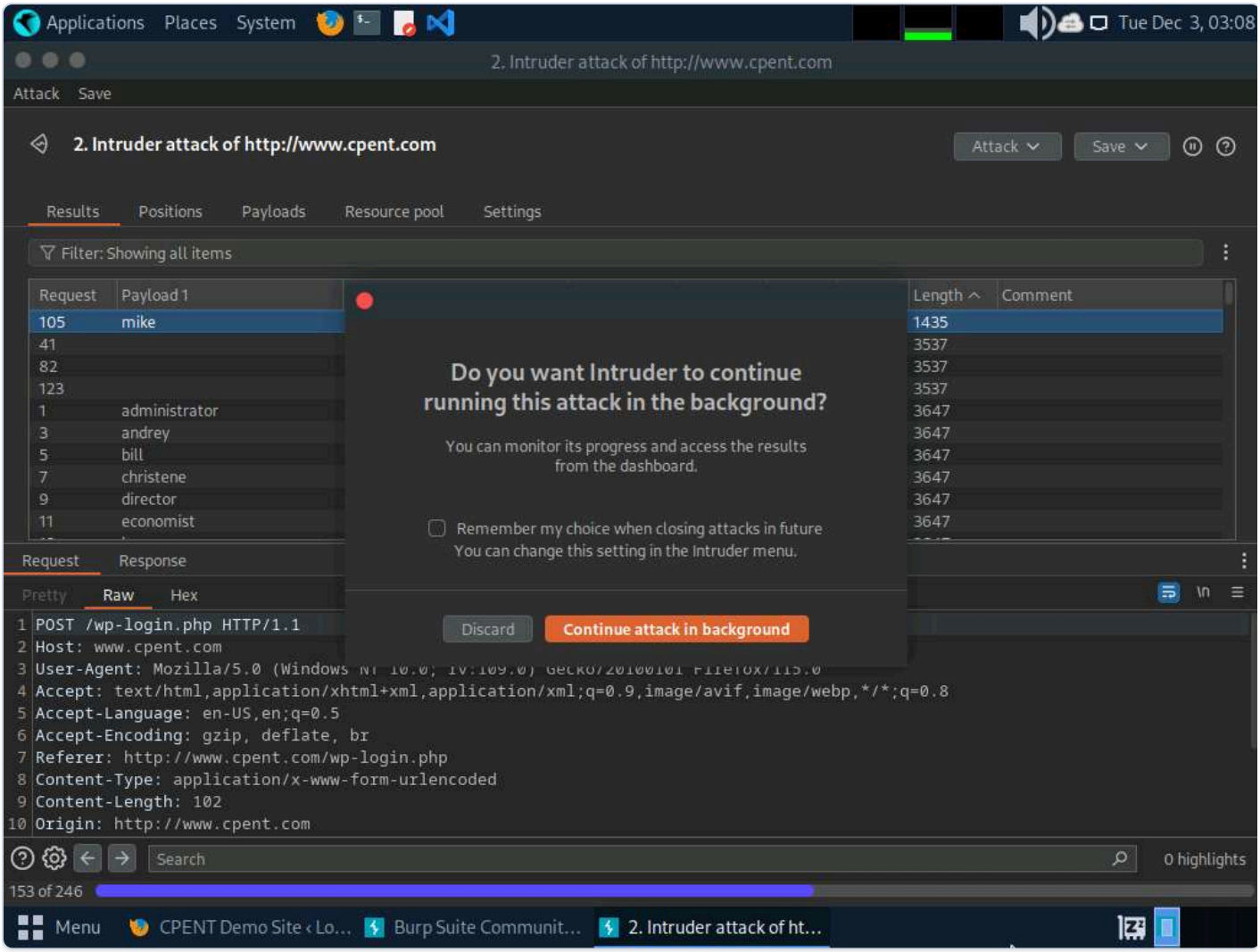
1. Intruder will iterate through all username-password permutations. Click **Length** in the response table header to sort responses by size.

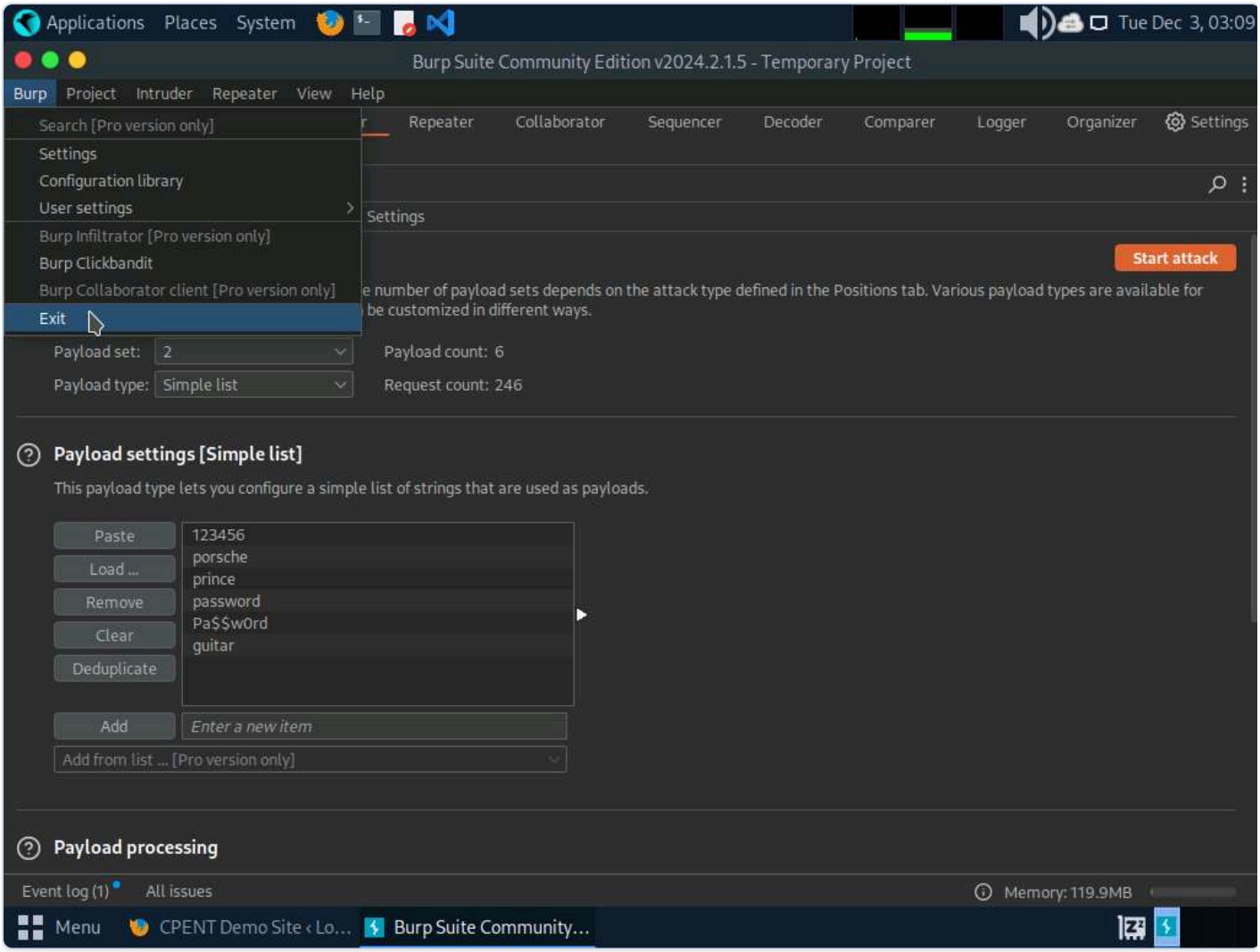


1. Observe that the response length and status for username **mike** and password **prince** significantly differ from invalid combinations, identifying valid credentials.

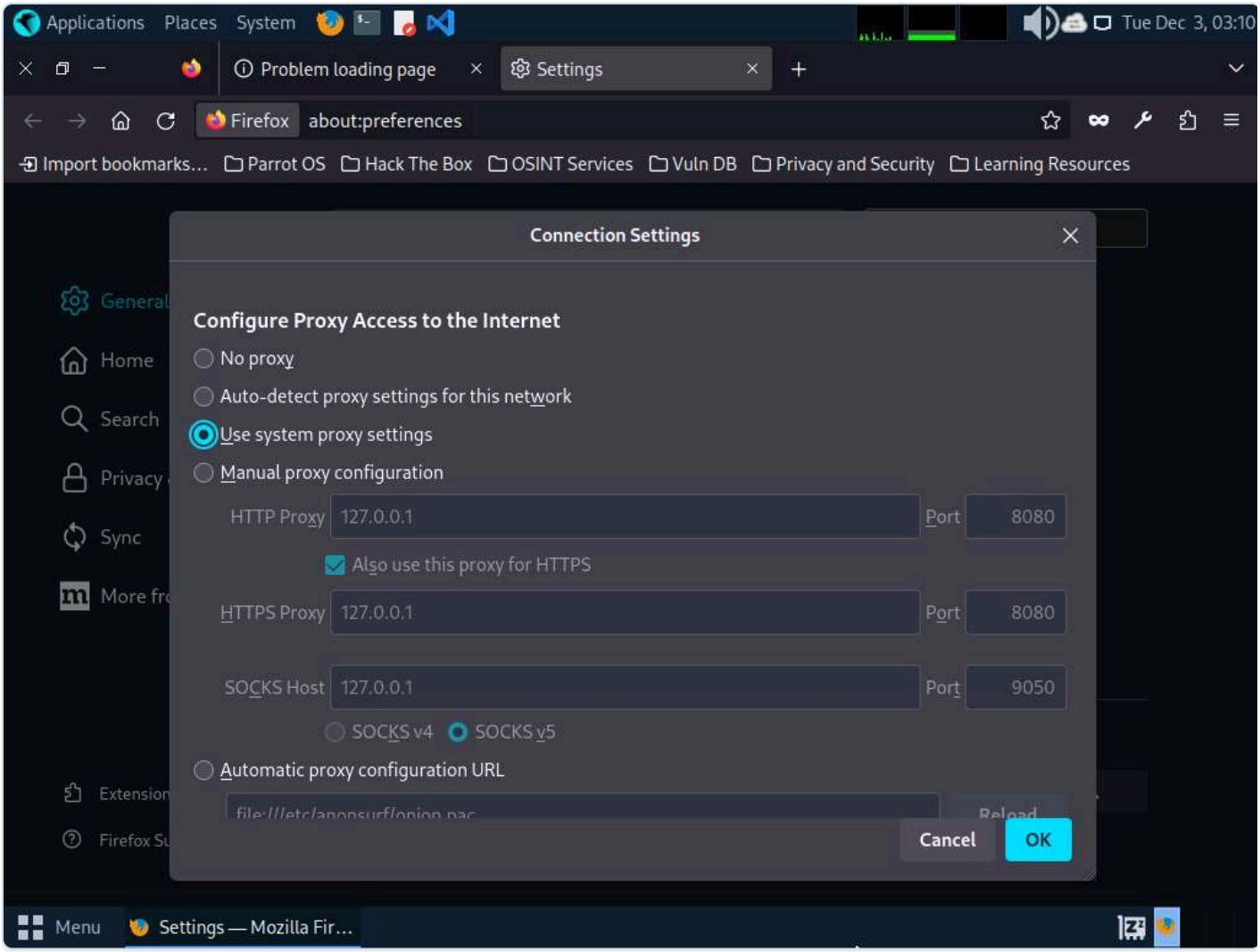


1. Close the Intruder Attack window (click Discard if prompted). Exit Burp Suite.

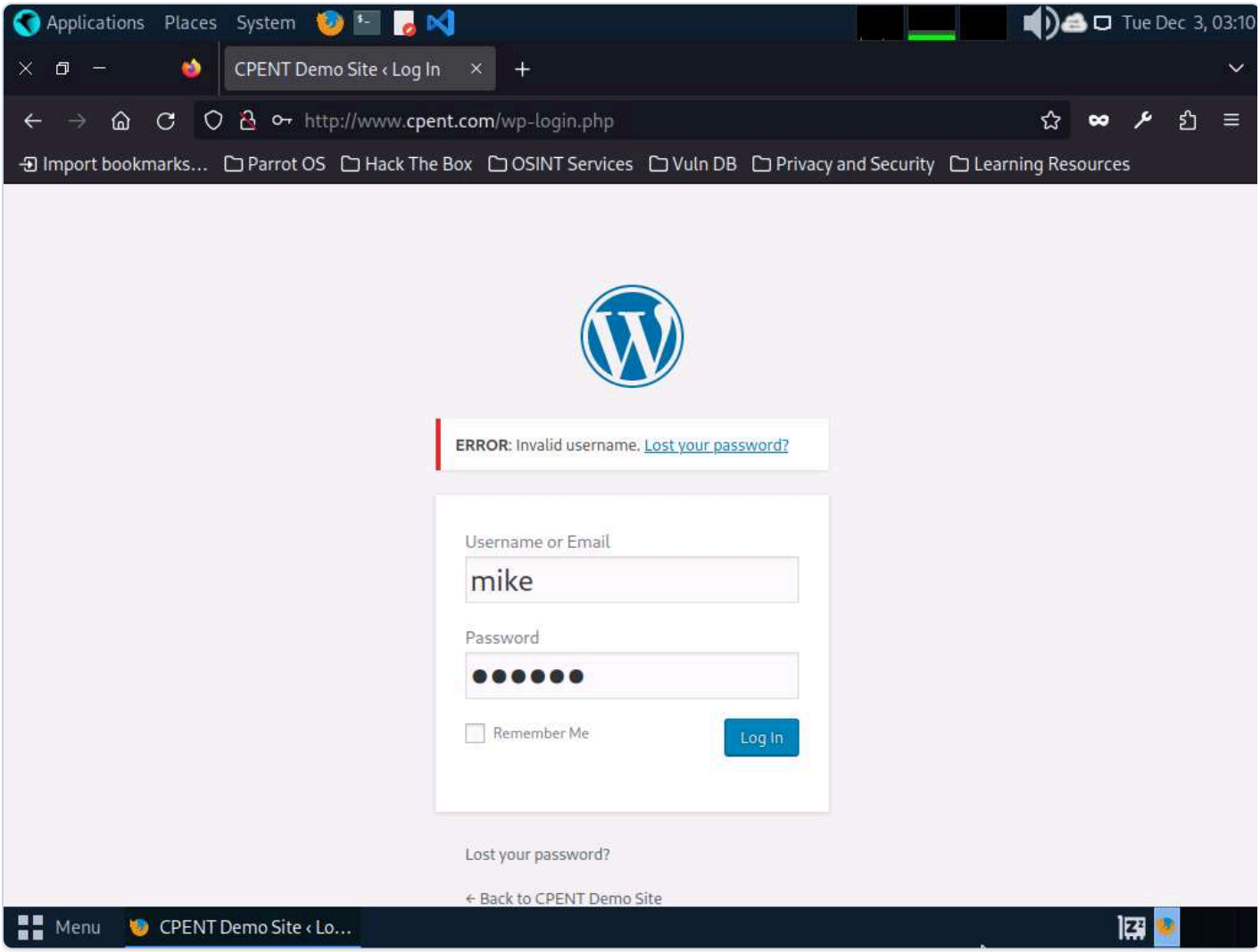

Applications Places System
Tue Dec 3, 03:08
2. Intruder attack of http://www.cpent.com
Attack Save
2. Intruder attack of http://www.cpent.com
Attack
Save
Results Positions Payloads Resource pool Settings
Filter: Showing all items
Request Payload 1
105 mike
41
82
123
1 administrator
3 andrey
5 bill
7 christene
9 director
11 economist
Length Comment
1435
3537
3537
3537
3647
3647
3647
3647
3647
3647
Do you want Intruder to continue running this attack in the background?
You can monitor its progress and access the results from the dashboard.
Remember my choice when closing attacks in future
You can change this setting in the Intruder menu.
Discard
Continue attack in background
Request Response
Pretty Raw Hex
1 POST /wp-login.php HTTP/1.1
2 Host: www.cpent.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://www.cpent.com/wp-login.php
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 102
10 Origin: http://www.cpent.com
Search
0 highlights
153 of 246
Menu
CPENT Demo Site ‹ Lo...
Burp Suite Communit...
2. Intruder attack of ht...



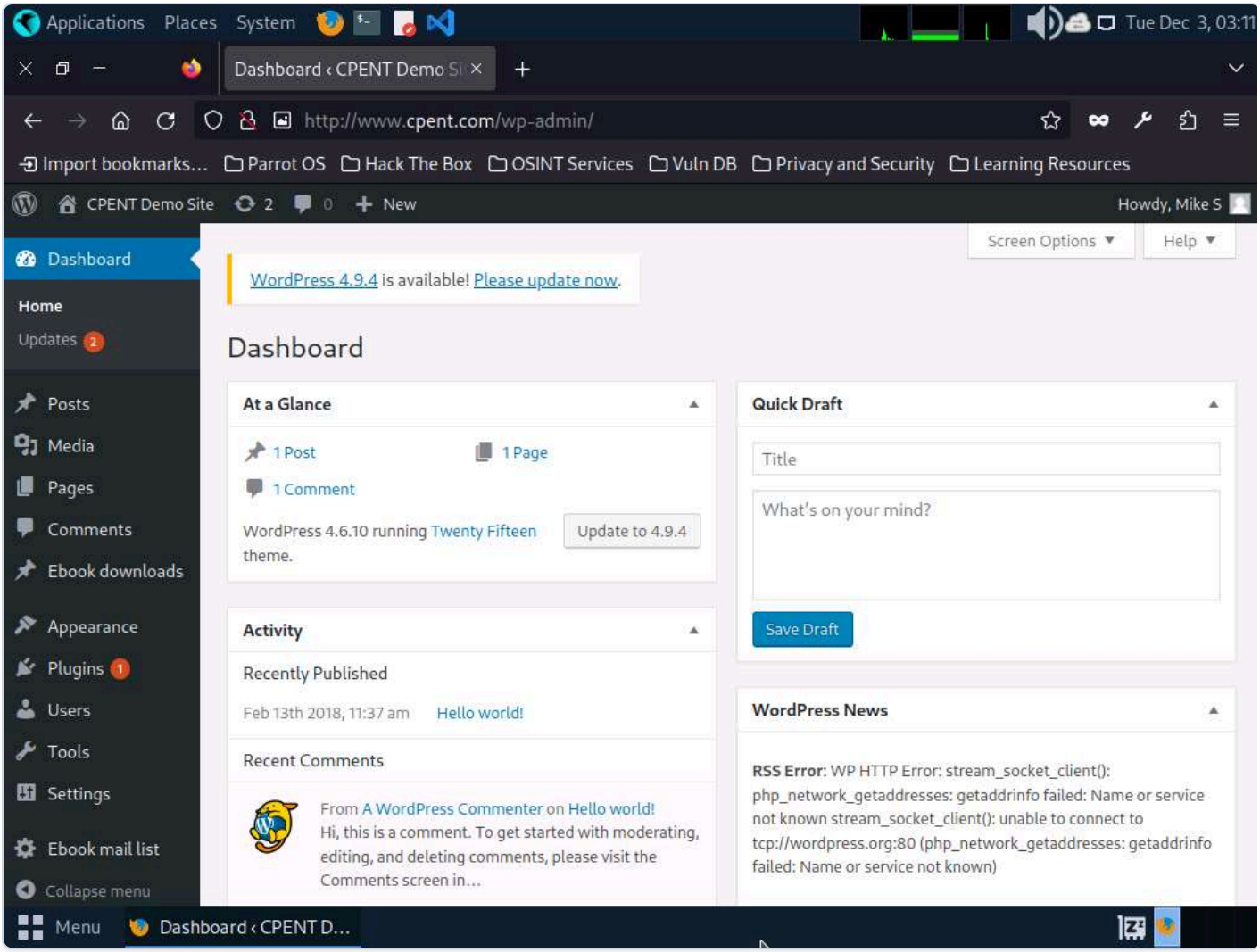
1. In Firefox Settings, revert proxy configuration to **Use system proxy settings** and click **OK**.



1. Return to **http://www.cpent.com/wp-login.php**, enter **mike** / **prince**, and click **Log In**.



1. Confirm successful authentication to the WordPress Dashboard.



This concludes the lab exercise. Close all open windows.

IMPORTANT: ❓ **Question 5.6.1.1** On the Parrot Security machine, conduct a dictionary attack on the WordPress web application at `http://www.cpent.com` using Burp Suite to gain unauthorized access to user accounts. Utilize the wordlists available in `CPENTv2 Pen Testing Resources/Wordlists/`. Identify and enter the password associated with the user "mike" on the target website. [!SUCCESS] ✅ **Answer:** **prince**